

SOC ANALYST DAILY POCKETBOOK 2026

**BY IZZMIER
IZZUDDIN**

Table of contents

Running the shift

01 Start of shift checklist4

02 Alert queue prioritisation6

03 The first 5 15 and 30 minutes8

04 Shift handover checklist 10

05 End of shift checklist 12

Investigation essentials

06 Event alert case and incident..... 14

07 Seven questions for every investigation..... 16

08 Severity priority and confidence..... 18

09 Investigation pivot map20

10 Building the timeline22

11 True positive benign positive and false positive24

12 Writing notes and escalating clearly.....26

Investigating artefacts

13 Investigating an IP address28

14 Investigating a domain30

15 Investigating a URL.....32

16 Investigating a file hash34

17 Investigating a suspicious file36

18 Investigating an email38

19 Investigating a user account40

20 Investigating a process and command line42

21 Investigating a host or device.....44

22 Investigating a CVE46

Table of contents continued

Essential logs

- 23 Windows authentication event IDs.....48
- 24 Windows account and group changes.....50
- 25 Process service and scheduled task events52
- 26 Essential Sysmon events.....54
- 27 PowerShell and AMSI logs56
- 28 Active Directory and Entra ID logs58
- 29 Email and Microsoft 365 logs60
- 30 EDR process file and network telemetry62
- 31 Firewall proxy DNS and VPN logs64
- 32 Linux and cloud audit logs66

Daily alert playbooks

- 33 Phishing email68
- 34 Malicious link or attachment70
- 35 Business email compromise72
- 36 Brute force and password spraying74
- 37 Suspicious successful login76
- 38 Impossible travel MFA fatigue and token replay78
- 39 New administrator or suspicious OAuth application80
- 40 Suspicious PowerShell or script execution82
- 41 Suspicious process tree or LOLBin84
- 42 New service scheduled task or persistence.....86
- 43 Credential dumping and LSASS access.....88
- 44 Suspicious DNS beaconing or command and control90
- 45 Port scan exploitation or WAF alert92
- 46 Data staging and exfiltration94
- 47 Ransomware and mass file modification.....96

Table of contents continued

Kali for defensive use

48 File identification hashing and metadata.....98

49 IP domain and DNS investigation commands 100

50 HTTP redirects and TLS investigation..... 102

51 PCAP analysis with TShark Wireshark and Zeek 104

52 Windows event hunting with Chainsaw and Sigma..... 106

53 Static malware Office and PDF analysis 108

Response and reporting

54 Containment decision matrix 110

55 Identity compromise response 112

56 Endpoint compromise response 114

57 Phishing and BEC response 116

58 Ransomware response 118

59 L1 to L2 to incident response escalation 120

60 Incident summary closure and handover 122

Appendices and references

Appendix A Any alert checklist 124

Appendix B Ports and protocols 125

Appendix C Windows event quick table 126

Appendix D Sysmon and PowerShell quick table 127

Appendix E Process relationships worth reviewing 128

Appendix F OSINT bookmarks for artefacts 129

Appendix G Local defensive command sheet..... 131

Appendix H QRadar AQL query patterns 132

Appendix I Severity and escalation matrix 135

Appendix J Case and evidence templates 136

Technical references 138

01 Start of shift checklist

Check this first

Read the outgoing handover before touching the queue. Identify every open critical or high-priority incident, its current owner, the next decision and the promised update time. Confirm the on-call analyst, incident commander and backup contact. A case without an acknowledged owner is still your problem.

- Check SIEM ingestion, EDR coverage, identity logs and email telemetry. Compare last event time with normal arrival delay.
- Review isolation failures, disabled detections, maintenance windows and approved security tests.
- Check urgent vendor advisories against the asset inventory. An advisory is relevant only after product, version and exposure are established.
- Identify production changes, privileged maintenance, VIP travel and known business events that could affect interpretation.

Use these logs

Use the incident queue, handover record, collector heartbeat, sensor-health console, change calendar and current asset register. Check both event timestamps and ingestion timestamps; a green connector does not guarantee fresh events.

Use these tools

Open SIEM, EDR, identity, mail-security and case-management consoles in approved profiles. Keep the internal contact list and the OSINT bookmark sheet ready. Use approved external research services only; do not upload internal records to public scanners or AI tools.

01 Decisions and response

What the result means

A quiet queue with silent telemetry is an observability problem, not evidence of safety. A high alert count during a test may be expected, but the test scope does not explain unrelated activity. Validate the tester, authorised hosts and time window before applying an exception.

Take this action

Create a short readiness entry: shift start in UTC and local time, analyst, active incidents, missing feeds, planned changes and next checkpoint. Assign a ticket owner for each gap and state which assets or detections are affected. Ask the outgoing analyst to confirm any ambiguous containment state.

Schedule one brief mid-shift health check. If capacity is constrained, prioritise active harm and critical assets while retaining the original alert arrival times. Follow locally approved service targets; this pocketbook does not set contractual SLAs.

Escalate when

No responder is available for an active incident; a critical log source is unavailable; containment failed; or the previous shift cannot establish whether malicious activity stopped. Use the emergency path immediately when there is ongoing harm.

Worked example

The queue contains four medium alerts, but the domain-controller feed last reported two hours ago. Confirm the source clock and collector first, open a telemetry incident, and temporarily use native identity records. Do not report zero authentication attacks for the missing interval.

Record: readiness time, affected feed, last good event, fallback source, ticket owner and next update. Related cards: 02, 04, 05 and 59.

02 Alert queue prioritisation

Check this first

Rank alerts by observed activity and business context. Active encryption on a file server normally requires faster action than a large batch of blocked scans. Check asset criticality, exposed data, privilege, attack progression and whether the activity is continuing.

- Separate active harm from historical detections.
- Identify successful access, execution, persistence, credential access and data movement.
- Check whether multiple alerts describe the same event chain.
- Review age, ownership and local response targets. An old low-severity alert can conceal an uninvestigated compromise.
- Keep confidence separate from impact. Uncertain evidence on a critical asset may still justify urgent escalation.

Use these logs

Start with raw triggering events, asset ownership, identity privileges and preceding alerts. Read the rule logic and time window. A vendor label alone cannot explain why the alert fired.

Use these tools

Use SIEM entity views and EDR timelines to group by device, account, session and indicator. Count unique entities as well as events. Deduplicate related cases without deleting evidence or losing original timestamps.

02 Decisions and response

What the result means

High volume can mean a campaign, an ingestion replay or a broken rule. A single event can matter more if it grants a privileged role or disables protection. A block action means a control acted on that event; it does not establish that earlier execution or another channel was blocked.

Take this action

Use a locally approved queue order: immediate harm; confirmed compromise; credible suspicious activity on critical assets; ordinary triage; informational work. Keep an analyst assigned to each active incident. Reassess priority whenever new evidence changes scope or impact.

If a detection storm arrives, sample raw records from several sources and times before suppressing anything. Use a narrow, time-limited exception with an owner and expiry. Preserve a query that can retrieve all excluded events for review.

Escalate when

The queue exceeds available response capacity, high-priority cases lack owners, or alert flooding prevents detection of ongoing harm. Ask for additional coverage and document which work is deferred.

Worked example

Three hundred denied inbound connections and one unauthorised administrator addition arrive together. Check the administrator change immediately while another analyst validates the scan scope. If the account then accesses backup infrastructure, raise priority again.

Record: prioritisation reason, affected service, current confidence, assigned owner and next decision. Avoid changing severity merely to improve queue metrics. Related cards: 08, 39 and 54.

03 The first 5 15 and 30 minutes

Check this first

These are suggested operational checkpoints, not a promise to complete every investigation in 30 minutes. Urgent containment may need to precede a full evidence package when destructive activity is underway and authority already exists.

- First five minutes: acknowledge, preserve the trigger, identify the account and asset, confirm time zone, check whether the activity is ongoing and appoint an owner.
- By fifteen minutes: validate the signal, build an initial timeline, identify related entities, assess likely impact and request containment where justified.
- By thirty minutes: report known scope, actions verified, unresolved questions, owners and the next update time.

Use these logs

Retrieve the trigger plus a bounded window before and after it. Expand backward when you find an earlier suspicious event. Use endpoint, identity and network evidence to avoid relying on one source.

Use these tools

Save exact queries and exports in the case. Use approved response actions through the owning team. A requested isolation or account disablement is not complete until its result is verified.

03 Decisions and response

What the result means

The first alert is the detection time, not necessarily the compromise time. An account reset may occur after an attacker created persistence. A missing result may mean the device is offline or the action never reached it.

Take this action

Maintain three short lists: confirmed facts, working hypotheses and unknowns. Keep each statement attached to evidence. Start scope with the initiating account, source device, destination and time; then search the same behaviour across the environment.

Preserve raw events and volatile evidence when feasible, but do not prolong active encryption just to complete routine collection. Record the reason for emergency action and any evidence that could not be captured. The incident commander should balance evidence preservation with harm reduction.

Escalate when

There is active data loss, destructive behaviour, privileged access, multiple affected hosts, a critical business service or an inability to contain. Do not wait for the next checkpoint to call.

Worked example

At 09:00 UTC an endpoint reports mass file writes. At 09:03 the analyst confirms a suspicious process and requests authorised isolation. At 09:06 the console confirms isolation. At 09:12 a second host is identified. The 09:15 update states two affected hosts, one verified isolated and one action pending; it does not say the incident is contained.

Record separate detection, acknowledgement, containment-request and containment-confirmation timestamps. Related cards: 10, 47 and 58.

04 Shift handover checklist

Check this first

Hand over decisions and outstanding risk, not a pasted wall of alerts. The incoming analyst should understand what changed, what evidence supports it and what must happen next without repeating completed work.

- Case ID, priority, business service and named owner.
- Last confirmed malicious activity and current containment state.
- Accounts, hosts and data in scope, with confidence limits.
- Completed queries, time windows and evidence locations.
- Pending actions, action owners and due times.
- Explicit triggers for escalation or reopening.

Use these logs

Use the case timeline, response-action audit trail, vendor ticket and communications log. Check that the handover matches the actual console state. Reconcile conflicting descriptions before the shift ends.

Use these tools

Use the approved case system as the source of truth. Link to protected evidence instead of attaching customer data to broad chat channels. Use a live briefing for active incidents, then capture the acknowledgement in writing.

04 Decisions and response

What the result means

An action marked sent is different from one marked completed. A case awaiting an endpoint owner still needs an analyst owner. A message delivered to a group does not mean anyone accepted responsibility.

Take this action

Use this handover sentence: "Case, current risk, verified action, pending decision, owner, next update." Include the current investigation hypothesis and one alternative explanation. State which logs were unavailable so the next analyst does not interpret an incomplete search as negative evidence.

Transfer any time-sensitive responsibilities explicitly: credential rotation, evidence collection before retention expires, contact with a vendor, and validation after restoring a host. The outgoing analyst retains ownership until the incoming analyst acknowledges the transfer or the shift lead assigns it.

Escalate when

There is no receiving owner, the evidence cannot be accessed, a containment action remains unverified, or the next deadline falls before another responder is available.

Worked example

"SOC-026, high: unauthorised inbox forwarding on a finance account. Sessions revoked at 12:14 UTC; new sign-ins absent through 12:40 in available logs. Rule export preserved; deletion confirmed. Mail-access scope still unknown because audit export is pending. L2 Noor owns the next review at 13:00 UTC. Escalate on further sending or new forwarding."

This wording distinguishes observed facts from the unresolved data-access question. See the reusable template in Appendix J and card 59.

05 End of shift checklist

Check this first

Review every case you touched. Confirm that its status, severity, evidence links and next action reflect the latest findings. Do not close a case simply because the shift is ending or the indicator is no longer active.

- Ensure active cases have acknowledged owners.
- Record unresolved telemetry and sensor gaps.
- Confirm that temporary rules, exceptions and blocks have expiry or review dates.
- Check that evidence is stored under the correct access controls.
- Record promised stakeholder updates and vendor callbacks.
- Remove sensitive investigation data from temporary personal notes according to retention policy.

Use these logs

Compare the case queue with response-action history and your investigation notebook. Verify that planned actions were actually submitted and that submitted actions have results.

Use these tools

Use the case-system task list, evidence register and shift dashboard. Export approved artefacts to controlled storage; never transfer live credentials, session cookies or malware to personal cloud accounts.

05 Decisions and response

What the result means

A tidy queue is not the objective if it conceals unresolved risk. Pending monitoring is a valid state when it has a defined duration, owner, trigger and end condition. "Monitor" alone is not an action plan.

Take this action

For each case, state one of three outcomes: closed with supported disposition; escalated and acknowledged; or open with a specific next action. Include any queries that returned no results and the coverage limitations of those queries.

Count operational outcomes separately from alert volume. Record confirmed incidents, benign activity and duplicate alerts distinctly. Do not treat each IOC hit as a separate incident. If the next shift inherits an overdue action, tell the lead rather than silently resetting the clock.

Escalate when

Unresolved risk has no owner, evidence may expire, a sensitive export is misplaced, or the next shift cannot access the required system. Report a suspected disclosure immediately through the internal process.

Worked example

A URL investigation finds one user click and no process execution in EDR. The sensor was healthy, but browser telemetry is missing for ten minutes. Close only if the remaining evidence and local criteria support the disposition; otherwise hand over the browser review with that precise gap.

Record the approved storage location and retention date. Leave the working environment ready for the next shift without destroying incident evidence. Related cards: 11, 12 and 60.

06 Event alert case and incident

Check this first

An event is an observed occurrence, such as a logon. An alert is a detection that asks for review. A case is the work record used to investigate one or more related observations. An incident is activity that meets the organisation's declaration criteria because security or business operations are compromised or threatened.

- Read the raw event before accepting a rule title.
- Check whether the case contains one event, a sequence or several unrelated entities.
- Identify the specific behaviour the rule detected.
- Apply local declaration criteria and record who made the decision.

Use these logs

Use original telemetry, the detection rule and case correlation history. Preserve source record IDs and the rule version where available. An event ID without its provider and channel can be ambiguous.

Use these tools

Use SIEM correlation views for leads, then return to raw records. Treat an EDR incident grouping or SIEM offence as a product grouping that still requires analytical validation.

06 Decisions and response

What the result means

A firewall denying a known malicious source is a security event and may trigger an alert. It is not automatically a successful intrusion. Conversely, a single successful unauthorised mailbox session can justify an incident even if no malware alert exists.

Take this action

Describe what happened in observable terms before assigning a label. For example: "An external source attempted 32 TCP connections; all logged attempts were denied" is stronger than "32 attacks stopped" when only one sensor was checked.

Keep business impact separate from technical classification. A malware attempt blocked before execution may be a true detection with no confirmed compromise. A valid account used without authorisation can be a compromise even when authentication technically succeeded.

Use NIST SP 800-61 Rev. 3 as the incident-response reference within CSF 2.0. This book's checkpoints are operational guidance, not official NIST time limits.

Escalate when

The declaration threshold is met, evidence shows unauthorised access, or uncertainty concerns a critical asset. Ask the incident lead to resolve classification disputes without delaying urgent action.

Worked example

One case links a phishing email, a browser sign-in and a mailbox forwarding change. These are three observations supporting one account-compromise incident. Preserve all three rather than reporting three independent incidents.

Reference: R01. Related cards: 08, 11 and 60.

07 Seven questions for every investigation

Check this first

Answer the following questions with evidence rather than assumptions.

1. Who acted: account, service principal, process and likely human owner?
2. What happened: attempted action, successful action or control response?
3. When: first observed, last observed and detection time in a stated zone?
4. Where: source, destination, host, tenant, application and network zone?
5. How: access path, execution chain and relevant control behaviour?
6. How far: other accounts, hosts, resources and data potentially involved?
7. What impact: observed harm, plausible exposure and business consequence?

Use these logs

Select a source for each question. Identity logs establish authentication context; process telemetry establishes execution; application and data-access logs establish what the session actually did. A network connection alone cannot answer the data-access question.

Use these tools

Use the investigation pivot map in card 09. Preserve immutable identifiers such as object ID, device ID and process GUID; display names, IP addresses and PIDs can change or be reused.

07 Decisions and response

What the result means

An unanswered question is a task, not a reason to invent a conclusion. Mark each answer as observed, inferred or unknown. Confidence increases when independent sources support the same sequence, not simply when several services repeat the same indicator feed.

Take this action

Write an initial hypothesis and at least one plausible benign explanation. Identify the next observation that would distinguish them. Search a bounded interval, assess coverage and expand only when the evidence warrants it.

For an administrator action, compare the request with the change ticket, source device, usual operator and exact target. A matching maintenance window alone is insufficient. For suspected compromise, search subsequent activity even if the initial access method remains uncertain.

Escalate when

You cannot establish scope on a critical system, evidence contradicts the current disposition, or an attacker may still have access while you wait for confirmation.

Worked example

An account downloads 600 files. Who: a valid finance user. What: successful downloads. When: outside its usual hours. Where: a new session. How: browser access. Scope: one library so far. Impact: potential disclosure. The next pivot is session ownership and file classification, not a malware scan alone.

Record the evidence supporting each answer and the specific owner for each unknown. Related cards: 10, 12, 19 and 46.

08 Severity priority and confidence

Check this first

Severity describes the potential or observed consequence. Priority describes how quickly action is needed. Confidence describes the strength of the evidence. Detection fidelity describes how reliably a rule identifies the intended behaviour over time. Keep these values separate.

- Identify whether harm is ongoing.
- Determine asset, account and data criticality.
- Check scope and the possibility of escalation or propagation.
- Verify which actions succeeded, failed or remain unknown.
- Consider exposure and business dependencies before selecting containment.

Use these logs

Use confirmed behaviour, asset ownership, data classification, identity role and response status. Reputation scores and vendor severity are inputs; they are not substitutes for organisational context.

Use these tools

Use Appendix I as an example matrix and replace it with local definitions. Agree escalation paths and time targets in the SOC's approved procedure. There is no universal threshold that fits every environment.

08 Decisions and response

What the result means

Low confidence does not always mean low priority. An unverified destructive alert on a critical server may require immediate validation. High confidence in a blocked commodity scan does not make it a critical incident.

Take this action

Write a short rationale: "High priority because a privileged session is active on production; medium confidence because the owner has not yet confirmed it." Reassess after each material finding. Preserve the original severity and the reason for any change.

Use impact dimensions that the business understands: service availability, unauthorised changes, sensitive data, financial transactions and recovery capability. State observed impact separately from potential impact. Do not report exfiltration as confirmed solely because outbound bytes increased.

Escalate when

Critical services, privileged identities, sensitive data or recovery systems are involved; containment is delayed; or the incident crosses the current analyst's authority. Escalate uncertainty explicitly when waiting would increase risk.

Worked example

A newly created cloud administrator originates from an unfamiliar network. The account owner denies the change, audit logs show successful role assignment, and a storage key is accessed. Confidence and priority rise because independent evidence supports unauthorised privilege and follow-on action.

Record: severity, priority, confidence, rationale, decision time and approver where required. Related cards: 02, 39 and 54.

09 Investigation pivot map

Check this first

Start with the alert's strongest entity and move to evidence that answers a specific question. Do not enrich every field without a purpose. A good pivot either expands scope, tests a hypothesis or establishes impact.

- IP to internal device: DHCP, VPN, NAT and proxy mappings at event time.
- Account to session: identity ID, logon ID, authentication method and application.
- Host to process: device ID, process GUID, command line and parent.
- Process to file and network: hashes, writes, child processes and destinations.
- Domain to infrastructure: historical DNS, certificates and observed resolutions.
- Cloud identity to resource: role assumption, API action, object and result.

Use these logs

Use time-aware joins. An IP-to-host mapping from today may be wrong for yesterday. A hostname can be reused after reimaging. A PID must be linked to the host and process start time.

Use these tools

Use SIEM joins, EDR entity views and internal asset records before public enrichment. Record the time span and fields used for each relationship.

09 Decisions and response

What the result means

Association does not prove common ownership. Shared hosting, CDNs, public resolvers and mail gateways can connect unrelated entities. Certificate reuse is a lead whose strength depends on how specific and common the certificate is.

Take this action

Build a small evidence graph in the case notes: entity A, relationship, entity B, timestamp and source. Mark direct observations separately from inferred connections. Search the same behaviour across peers after you understand the first example.

Limit queries by time, source and entity to avoid overloading production systems. Increase scope deliberately. Keep the original raw value and a normalised search value, especially for URLs, case-sensitive paths and usernames with multiple formats.

Escalate when

A pivot reaches a privileged account, another network zone, a second host, sensitive storage or a third-party tenant. Reassess incident scope rather than attaching the new evidence to an old low-priority alert without review.

Worked example

Firewall source 10.20.8.17 resolves through the event-time DHCP record to WS-017. EDR links its connection to process GUID P17. The parent is an archive utility that opened a shortcut from Downloads. These relationships support an execution chain; the IP reputation alone did not.

Record every join key and any ambiguity. Related cards: 13, 19, 20 and 21.

10 Building the timeline

Check this first

Preserve source timestamps exactly as received, then create a separate normalised UTC timestamp. Record the time zone, precision, clock drift and ingestion delay. For Malaysia, 21:00 at UTC+08:00 corresponds to 13:00 UTC on the same date.

- Separate event time from collection and ingestion time.
- Identify first known malicious activity and last confirmed activity.
- Include relevant benign events, such as approved maintenance or a user report.
- Preserve source record IDs and the query that retrieved each item.
- Distinguish attempted, successful, blocked and unknown outcomes.

Use these logs

Correlate endpoint, identity, application and network events. Check clocks against a trusted time source. Do not force uncertain timestamps into an exact causal order.

Use these tools

Use the case timeline or an approved spreadsheet with columns for original time, zone, UTC, entity, action, result, evidence ID and confidence. Keep raw evidence separate from the edited timeline.

10 Decisions and response

What the result means

Chronological proximity supports a hypothesis but does not prove causation. An email arriving before PowerShell does not prove the email launched it. A process GUID, file path, session or parent relationship supplies the missing link.

Take this action

Start around the alert, then work backward to the earliest supported precursor and forward to impact and containment. Mark gaps explicitly. If a source is five minutes slow, retain its original timestamp and explain the correction rather than silently changing the evidence.

Record response actions on the same timeline: approval, request, completion and validation. State the observation window used to conclude that activity stopped. If logs arrive late, revisit the timeline and preserve revision history.

Escalate when

Time uncertainty prevents reliable scoping, log retention may expire, or evidence suggests activity predates the current search window. Ask for native exports before rotation removes the records.

Worked example

13:00:10 UTC: phishing click. 13:00:18: shortcut creates a script process. 13:00:22: that process connects outward. 13:05:00: isolation requested. 13:05:40: isolation confirmed. An outbound event ingested at 13:07 but timestamped 13:04 does not by itself prove isolation failed.

Record original and normalised times together. Related cards: 03, 07, 12 and Appendix J.

11 True positive benign positive and false positive

Check this first

Determine whether the rule correctly detected the behaviour it was designed to detect. Then determine whether that behaviour was malicious, authorised or unresolved. These are different decisions.

- True positive malicious: the intended behaviour occurred and evidence supports malicious or unauthorised activity.
- Benign positive: the intended behaviour occurred but has a verified legitimate explanation.
- False positive: parsing, rule logic or context incorrectly represented the intended behaviour.
- Inconclusive: evidence is insufficient for a defensible decision.
- Duplicate: another case already owns the same activity and evidence.

Use these logs

Read the rule condition, raw records, authorised change and outcome evidence. User confirmation helps, but compare it with the actual action, device and timestamp.

Use these tools

Use a local disposition taxonomy consistently. Some products group benign positives under false positives; preserve the analytical reason in notes even when the interface has fewer choices.

11 Decisions and response

What the result means

A signed tool used by an administrator can still be abused. A clean antivirus scan cannot refute stolen-session activity. No hits in an incomplete dataset do not establish that an event never happened.

Take this action

For closure, record the detected behaviour, evidence reviewed, time range, scope, authorised explanation if any, action taken and remaining limitations. If telemetry is missing, resolve the gap or obtain a risk-based decision from the appropriate owner.

For tuning, describe the exact source of noise. Prefer narrow conditions with expiry and verification over broad allowlists for a binary, administrator or entire subnet. Keep a sample event and test the proposed change against known malicious behaviour.

Escalate when

The owner denies activity, evidence conflicts, the supposed exception is not approved, or the rule appears to miss similar malicious behaviour. A suspected false negative deserves a detection-quality ticket and incident review where applicable.

Worked example

A rule detects a new scheduled task. A documented deployment created the exact task using the expected signed agent on approved devices. This is a benign positive if the task-creation detection is accurate. It is not proof that all future tasks from that agent are safe.

Record the approver and change ID. Related cards: 12, 42 and 60.

12 Writing notes and escalating clearly

Check this first

Write notes so another analyst can reproduce your work. Use concrete statements with evidence references. Separate facts, inference and unknowns. Avoid "looks fine", "all clean" and "blocked" without the scope and proof behind them.

- State the question being investigated.
- Save the exact query, platform, time range and time zone.
- Record event counts and distinct affected entities.
- Link raw evidence and any transformed output.
- Explain the interpretation and next pivot.
- Name the action owner and review time.

Use these logs

Include the original trigger, supporting events and relevant negative searches with coverage limits. Screenshots can help explain a console view but should not replace exportable raw evidence when available.

Use these tools

Use a protected case record and evidence register. Hash exported files where integrity tracking is needed. Keep secrets, tokens and personal data in restricted evidence locations, not general chat.

12 Decisions and response

What the result means

Clear escalation is a decision request. The recipient should know what happened, why it matters, what has been verified and what authority or expertise is needed. A long attachment without a specific request delays response.

Take this action

Use this structure: finding; scope; evidence; action completed; uncertainty; decision required; next update. Cite record IDs and UTC timestamps. When communicating with management, translate the technical result into service, data or financial consequence without claiming unproven impact.

Keep evidence handling auditable: source, collector, collection method, timestamp, original path, hash, storage location and access history. Work on copies. Any transformation, such as decoding or redaction, should produce a separate derived artefact with its method recorded.

Escalate when

You need containment approval, forensic collection, application-owner support, legal review or a change to incident priority. Use the emergency channel for active harm and follow with a written record.

Worked example

"Request identity containment approval. User maya@example.com denies a successful session at 13:12 UTC. Audit record A17 shows an external forwarding rule created three minutes later. One account is confirmed in scope; mail-read volume is unknown. Please approve session revocation and rule removal after evidence capture. L2 owns scoping; next update 13:40 UTC."

The example is fictional. Use approved local recipients and deadlines.
Related cards: 04, 59, 60 and Appendix J.

13 Investigating an IP address

Check this first

Determine whether the address is internal, public, a proxy, a VPN exit, a CDN or a shared cloud service. Confirm its role in the raw event: initiator, destination, translated address or forwarded client. Use event-time DHCP and NAT records to identify an internal device.

- Check direction, protocol, port, action, bytes and session duration.
- Identify the initiating user and process where telemetry permits.
- Search preceding and subsequent connections from the same device.
- Compare the destination with normal activity and business dependencies.

Use these logs

Firewall, proxy, DNS, VPN, EDR network events, DHCP and NAT records. Source IP in a cloud audit record can represent a service or intermediary rather than the human operator.

Use these tools

Start with internal history, then VirusTotal, GreyNoise, AbuseIPDB and an ownership source such as RDAP. Shodan or Censys can provide previously observed services. Record observation dates and licence limitations.

Read-only local search:

```
rg -n -F '198.51.100.24' firewall.log
```

The example address is reserved for documentation. Live DNS and ownership queries send information to a third party; use approved access paths.

13 Decisions and response

What the result means

An abuse score describes reports, not the current event's outcome. GreyNoise observations can explain background scanning but do not prove every connection is benign. Geolocation is approximate; it does not identify an attacker. Shared hosting makes broad IP blocks risky.

Take this action

Build an evidence chain from connection to device, process and user. Search the same destination across the relevant period and compare unique hosts. If a suspicious domain resolves to a shared IP, prefer a precise domain or URL control when feasible and approved.

For denied traffic, check all relevant paths and earlier accepted sessions. For allowed traffic, establish whether the TCP session completed and whether application or endpoint evidence shows meaningful activity. An allowed firewall action alone is not successful exploitation.

Escalate when

A critical host has unexplained successful connections, the same process contacts several malicious destinations, or outbound traffic follows credential access or data staging. Include collateral impact before requesting a block.

Worked example

An IP has a high abuse score, but the observed traffic is a blocked inbound scan. A second event shows an internal script contacting the same IP over an allowed session. Investigate the script separately; neither event cancels the other.

Record: event-time ownership, direction, action, process, observed history, intelligence timestamp and confidence. Related cards: 09, 31 and 44.

14 Investigating a domain

Check this first

Preserve the exact hostname and distinguish it from the registrable domain. In login.example.com, example.com is the parent domain; a brand name elsewhere in the hostname does not establish ownership. Check Unicode and punycode forms without clicking the link.

- Identify where the domain appeared: email, DNS, proxy, script or application log.
- Capture current and event-time resolutions where available.
- Check registration, nameservers, certificates and first internal observation.
- Search for related users, hosts and paths.

Use these logs

DNS queries and answers, EDR DNS events, proxy requests, email URLs and browser telemetry. A DNS query proves a lookup, not necessarily a website visit or execution.

Use these tools

Use RDAP registration data, passive DNS, crt.sh, VirusTotal and approved historical sources. Use SecurityTrails only within the licensed access available. A live resolver query is not passive enrichment.

```
dig example.com A +noall +answer  
dig example.com AAAA +noall +answer  
dig example.com MX +noall +answer
```

These examples contact a DNS resolver. They do not enumerate or scan the target server.

14 Decisions and response

What the result means

Recent registration, cheap hosting or an unusual top-level domain are weak signals on their own. A valid TLS certificate proves a certificate relationship, not business legitimacy. A domain may have changed owner or hosting since the incident.

Take this action

Compare the domain with known business domains using an independently verified source. Check whether the suspicious content sits on a compromised legitimate site, a newly created imitation or a shared platform. Correlate the lookup with process and network activity.

Use historical evidence near the event time when attributing an IP or certificate. If the domain no longer resolves, retain the earlier DNS answer and cached intelligence. Document provider coverage rather than treating missing historical data as proof of absence.

Escalate when

Credential entry, payload download, command execution, repeated beaconing or brand impersonation is supported. Send takedown requests only through the authorised internal process; investigation does not confer permission to access or disrupt infrastructure.

Worked example

A user receives a link to payroll-reset.example. DNS logs show one lookup. Proxy telemetry shows a POST from that host and identity logs show a new session shortly afterward. Escalate suspected credential exposure and investigate the identity; the DNS event alone would not justify that conclusion.

Record the original hostname, normalised form, resolution time, sources, process and next pivot. Related cards: 15, 18 and 38.

15 Investigating a URL

Check this first

Copy the original URL into protected evidence without opening it. Parse scheme, hostname, port, path, query and fragment. Watch for misleading user-information fields, encoded characters and redirects. Preserve the original before creating a defanged or redacted copy.

- Check whether the URL contains passwords, reset tokens, customer identifiers or signed access parameters.
- Identify delivery and interaction: received, previewed, clicked, downloaded or submitted.
- Search existing intelligence before requesting a new scan.
- Determine whether a mail-security scanner generated the observed visit.

Use these logs

Email URL rewriting, click protection, proxy, browser, DNS, EDR and identity logs. Link-preview and sandbox requests may appear as clicks without user interaction.

Use these tools

Use existing VirusTotal and urlscan records, URLhaus for malware-delivery context, and an approved isolated browser if needed. A new urlscan submission actively visits the page. Unlisted is not private; vetted researchers and companies may access unlisted scans.

Do not send internal or token-bearing URLs to a public scanner. Even a private service still receives the submitted data.

15 Decisions and response

What the result means

A 200 response does not prove a page is benign. A 404 today does not refute malicious content yesterday. A clean reputation verdict is a current observation from limited sources, not a guarantee. Attackers can change content by region, browser or visit time.

Take this action

Preserve the redirect chain and final destination from existing telemetry. Determine whether credentials were entered, a file was saved or a command was copied and run. For ClickFix-style lures, investigate clipboard-to-shell activity and the browser-to-process timeline.

If active review is approved, use the isolated analysis environment without corporate sessions, cookies or credentials. Do not click unsubscribe, submit forms or replay signed URLs merely to inspect them. Follow the response path that matches observed interaction.

Escalate when

Credentials or tokens may be exposed, a download executed, sensitive data was submitted, or multiple recipients interacted. Request precise blocking or removal after validating scope and business impact.

Worked example

A rewritten email URL resolves through two redirects to a fake sign-in page. One human click is corroborated by browser telemetry; two other visits came from the mail scanner. Scope the user session and treat the scanner visits separately.

References: R08 and R09. Record URL, visibility choice, scan time, redirect evidence and interaction level. Related cards: 33, 34 and 38.

16 Investigating a file hash

Check this first

Identify the algorithm and where the hash came from. A SHA-256 value identifies exact bytes; it does not describe their behaviour. Recompute from the preserved file when available and compare with the sensor's value.

- Check whether the hash describes the archive, extracted file or memory-loaded image.
- Preserve original filename, path, size, signer and acquisition time.
- Search internal prevalence and first execution before using external reputation.
- Distinguish downloaded, quarantined and executed states.

Use these logs

EDR file and process records, email attachment metadata, proxy downloads and antivirus action results. Some sensors populate SHA-1 more consistently than SHA-256; search the fields actually available.

Use these tools

Search an existing VirusTotal report by hash before considering upload. MalwareBazaar and ThreatFox can supply malware context. Do not download samples during ordinary triage. Access, automation and commercial-use terms vary.

```
sha256sum evidence/sample.bin  
file evidence/sample.bin
```

Run local inspection in an approved analysis environment. A hash lookup sends the hash to the provider even though it does not upload the file.

16 Decisions and response

What the result means

Several detections increase suspicion but may share signatures or intelligence. Zero detections does not establish safety. Different hashes can represent the same malware family, and a signed file can still be malicious or abused. A file's internal timestamp can be manipulated.

Take this action

Compare reputation with provenance, execution and behaviour. Review available sandbox reports without assuming that behaviour occurred on your endpoint. Search across the environment for the same hash and related path, signer, command line or destination.

When a block is approved, verify which hash algorithm the control accepts and whether the policy reached the affected endpoints. Hash blocking may stop only that exact version. Continue searching for persistence and related artefacts.

Escalate when

The file executed with suspicious follow-on activity, is present on multiple assets, touches privileged credentials or appears in a trusted software distribution path.

Worked example

An archive hash has no external record. The extracted shortcut has another hash and launches a script. Search all relevant child artefacts; a clean archive lookup cannot resolve the case. If execution is unconfirmed, keep that uncertainty explicit.

Reference: R08. Record algorithm, value, exact object, intelligence date, local prevalence and execution evidence. Related cards: 17, 34 and 53.

17 Investigating a suspicious file

Check this first

Do not open or execute the file on a production workstation. Preserve the original bytes, acquisition method, path, timestamp and hash. Use a patched, isolated analysis environment with restricted network access and no corporate sessions.

- Identify real file type from content, not extension alone.
- Inspect archive contents without launching them.
- Check signer, embedded metadata and relevant strings.
- Determine delivery, execution and any child artefacts.
- Consider parser vulnerabilities even during static analysis.

Use these logs

File creation, downloads, quarantine history, process ancestry, script logs and network events. A blocked file write and a later successful execution can refer to different copies.

Use these tools

Use file, sha256sum, strings and ExifTool first. Use YARA, capa or document-specific tools for a focused question. Work on a copy and retain tool versions.

```
file evidence/sample.bin
sha256sum evidence/sample.bin
strings -a -n 6 evidence/sample.bin
```

Do not run recovered commands, follow embedded links or extract archives into shared production paths.

17 Decisions and response

What the result means

Strings and metadata are leads, not proof of execution. High entropy may reflect compression or encryption. A YARA match identifies a rule condition, not necessarily a definitive family. capa reports capabilities inferred from code; packed or unsupported samples may limit results.

Take this action

Connect file properties to endpoint behaviour. Determine whether the user saved, previewed or launched the file and whether children, persistence or connections followed. Search peers using several stable artefacts, not the filename alone.

If dynamic analysis is needed, use an approved sandbox with suitable confidentiality controls. Inspect submission and retention terms before sending anything. Do not upload internal documents, configuration files or customer data to public platforms. If lab expertise is unavailable, preserve and escalate.

Escalate when

Execution is confirmed, credential access or persistence is observed, the sample is protected or complex, or analysis could expose sensitive data. Escalate suspected supply-chain delivery to the incident lead and software owner.

Worked example

Invoice.pdf.lnk is identified as a shortcut rather than a PDF. Endpoint evidence shows the shortcut launched a script interpreter that contacted an external host. The misleading extension supports the delivery story; the process and network records establish execution.

References: R15 and R16. Related cards: 16, 34, 40, 48 and 53.

18 Investigating an email

Check this first

Preserve the original message with headers and attachments. Capture message identifiers, sender, reply-to, recipients and delivery time. A screenshot of the visible sender cannot establish the sending path.

- Compare display name, envelope sender and header From.
- Read trusted Received headers in the correct route context.
- Review the trusted gateway's authentication results.
- Identify links, attachments, payment requests and requested actions.
- Determine delivery and actual user interaction.

Use these logs

Message trace, gateway disposition, URL-click telemetry, mailbox audit, identity sign-ins and endpoint events. Record the provider's network message ID when available alongside the Internet Message-ID.

Use these tools

Use the internal header analyser or a local parser. Public header analysers may receive addresses, routing details and message identifiers. Strip sensitive data from a derived copy only when policy permits; retain the original unchanged.

SPF evaluates the sending path for its identity. DKIM validates a signature. DMARC evaluates alignment with the visible From domain. Forwarding and legitimate services can complicate results.

18 Decisions and response

What the result means

Authentication pass does not mean the message is safe. A compromised genuine mailbox can pass all checks. Authentication failure may reflect configuration or forwarding. Judge content, context and user interaction with the technical evidence.

Take this action

Search all recipients using message identifiers, sender infrastructure, subject variants, attachment hashes and URLs. Confirm who received, opened, clicked, supplied credentials or executed a file. Separate scanner interactions from human actions.

For payment changes, confirm through a known independent contact method. Do not reply to the suspicious thread or use its phone number. Preserve a copy before approved purge or rule removal, and check whether malicious activity extended into the mailbox or identity.

Escalate when

Credentials were entered, an attachment executed, money moved, external forwarding appeared or several users interacted. Route privacy and financial consequences through the appropriate response owners.

Worked example

An authenticated vendor message asks for a bank-account change. The vendor confirms by a known phone number that the request is unauthorised. Treat it as suspected vendor account compromise or impersonation and involve finance even though SPF and DKIM passed.

Record original message, route, recipients, interaction and business request. Related cards: 29, 33, 35 and 57.

19 Investigating a user account

Check this first

Resolve the account to an immutable identity and owner. Distinguish human users, service accounts, administrators, guests and workload identities. Check account status, assigned roles, usual devices and expected applications.

- Review interactive and non-interactive sign-ins separately.
- Check authentication method, device, session and application.
- Look for password, MFA, recovery-method and role changes.
- Review consent grants, new application credentials and mailbox changes.
- Contact the owner through a trusted channel outside the suspect session.

Use these logs

AD authentication, Entra sign-ins and audit, VPN, endpoint logons, SaaS activity and application data-access logs. Successful authentication does not prove legitimate use or successful access to every resource.

Use these tools

Use identity object IDs, logon IDs and session correlation where supported. Query a realistic baseline period and document retention. Search alternate username formats without merging unrelated accounts that share a display name.

Do not paste tokens or cookies into public JWT decoders. Decoding token fields does not verify the signature or validate the session.

19 Decisions and response

What the result means

A new location can result from a mobile carrier or VPN. MFA satisfaction may come from a prior claim rather than a new user challenge. An account can be compromised without a new password login if an attacker uses a stolen session or application permission.

Take this action

Build the account's action sequence after the suspicious session: mailbox access, downloads, role changes, application grants and administrative operations. Scope all affected applications and any device where credentials or tokens may have been stolen.

Contain using approved identity procedures. Password reset, session revocation, device containment and application-grant removal solve different problems. Check the target application's session behaviour; revocation may not end every existing session immediately.

Escalate when

The owner denies activity, privilege is elevated, sensitive resources were accessed, or the account remains active after containment. Treat service-account changes carefully because disabling them can interrupt production.

Worked example

A finance user's password is reset, but a malicious OAuth application still has a consent grant. Review and revoke that grant through the authorised owner and investigate its API activity. A password reset alone did not remove the application relationship.

References: R05, R06 and R10. Related cards: 28, 38, 39 and 55.

20 Investigating a process and command line

Check this first

Identify the process by device, start time and process GUID or equivalent unique key. PID alone is unsafe because operating systems reuse it. Capture full path, hash, signer, user, integrity level, parent and command line.

- Compare the path and filename with the expected binary.
- Inspect parent and child processes, not just the flagged process.
- Review files written, registry changes and network connections.
- Check whether the action matches approved administration.
- Decode suspicious arguments offline without execution.

Use these logs

EDR process telemetry, Windows 4688, Sysmon 1, PowerShell script blocks and relevant file/network events. Windows command-line capture depends on audit configuration and can contain secrets.

Use these tools

Use EDR graphs and local text tools. LOLBAS and GTFOBins explain how legitimate utilities may be abused. Their presence is a research lead; the actual command and context determine the case.

For encoded text, preserve the original and decoded output separately. Do not paste the decoded content into a shell.

20 Decisions and response

What the result means

A Microsoft-signed binary can run attacker-supplied content. A strange parent relationship may be legitimate automation. Conversely, a common process name under a user-writable directory can be masquerading. Check signature validity and trusted installation path rather than filename alone.

Take this action

Reconstruct the execution chain from delivery to action. Determine how the parent was launched and whether the child established persistence, accessed credentials or contacted the network. Search the same command pattern and parent-child relationship across peers.

For long commands, preserve exact escaping, quotes and encoding. A truncated SIEM field can hide the relevant argument; retrieve the native event or EDR record. Keep case-sensitive matching where the source requires it.

Escalate when

The process accesses sensitive memory, injects into another process, runs under elevated credentials unexpectedly or has suspicious external communication. Confirm the business effect before terminating system or production processes.

Worked example

A word processor spawns a shell, which creates a script interpreter that connects outward. The process tree and connection timing are concerning. Compare user interaction, document origin and script content before declaring the exact malware family.

References: R03, R04 and R07. Related cards: 27, 30, 40 and 41.

21 Investigating a host or device

Check this first

Resolve the device's stable identity, owner, business role, operating system and current network location. Check EDR sensor health, last-seen time and whether the host was rebuilt or renamed during the search period.

- Identify users and remote sessions around the alert.
- Review new processes, services, tasks and startup changes.
- Check inbound and outbound connections and unusual file activity.
- Review recent software deployments, patches and approved scans.
- Identify privileged sessions and credentials potentially exposed.

Use these logs

EDR, native event logs, authentication, DNS, DHCP, VPN, firewall and application records. A workstation scan cannot establish the state of a cloud session. A host's current IP may not represent its earlier address.

Use these tools

Use approved endpoint collection and response capabilities. For forensic work, preserve evidence before reimaging when feasible. Avoid installing ad hoc tools on production systems without authorisation because they change evidence and may affect service.

Record whether the device is online, isolated, partially reachable or awaiting action.

21 Decisions and response

What the result means

An offline sensor may indicate shutdown, network failure, removal or tampering. "Scan completed with no detection" is a specific control result, not proof that the host was never compromised. Sensor gaps limit any negative conclusion.

Take this action

Build an endpoint timeline and map each suspicious process to files, sessions and destinations. Scope neighbouring hosts and reused credentials when lateral movement is plausible. Request collection of volatile evidence through trained responders when needed.

If isolation is authorised, verify the result in the console and through available telemetry. Account for exceptions such as management channels. Do not assume endpoint isolation revokes cloud sessions or stops activity from another host.

Escalate when

The host is a domain controller, hypervisor, backup server or other critical system; evidence indicates kernel-level compromise; or isolation could disrupt essential services. Engage the system owner and incident commander.

Worked example

A laptop is isolated after suspicious execution, but the same user continues making cloud API calls from a different network. Treat device and identity containment as separate tasks and expand scope beyond the laptop.

Record device ID, asset role, sensor health, users, evidence gaps and verified containment. Related cards: 30, 42, 54 and 56.

22 Investigating a CVE

Check this first

Start with the vendor advisory. Confirm the exact product, component, version, deployment mode and exposure. A product name match or scanner banner is not enough; backported patches and configuration can change applicability.

- Establish whether the vulnerable feature is enabled and reachable.
- Check vendor fixes, workarounds and exploitation guidance.
- Check CISA KEV for known exploitation and FIRST EPSS for estimated near-term exploitation likelihood.
- Identify internet-facing and business-critical assets first.
- Look for evidence of attempted or successful exploitation.

Use these logs

Asset inventory, package/version records, vulnerability scans, WAF/IPS, application access and error logs, endpoint events and change records. Include appliances without EDR and management interfaces.

Use these tools

Use vendor PSIRT, CVE records, NVD, KEV and EPSS. EPSS estimates the probability of exploitation in the next 30 days at the vulnerability level; it is not the probability that your specific asset is compromised.

Do not run public exploit code against production simply to confirm exposure. Use approved non-destructive validation methods and maintenance controls.

22 Decisions and response

What the result means

CVSS expresses technical severity, not your actual exposure. KEV inclusion is strong exploitation context but not proof of compromise in your environment. Absence from KEV does not mean exploitation is impossible. A patch prevents future exploitation but does not remove established access.

Take this action

Document applicability, exposure, asset owner, remediation deadline under local policy and an evidence-based hunt. Use the vendor's indicators and behaviour guidance, then search for post-exploitation actions such as new accounts, web shells, configuration changes and outbound connections.

After remediation, verify the installed build or configuration and rescan as appropriate. Preserve incident evidence if compromise is suspected. Track unsupported systems and compensating controls with explicit owners and expiry.

Escalate when

An exploitable exposed asset is critical, exploitation is observed, the owner cannot remediate, or a proposed workaround significantly affects service. Treat confirmed post-exploitation as an incident, not merely a patch ticket.

Worked example

A WAF blocks one exploit request, but the vulnerable server had direct internet access before the rule was enabled. Hunt the earlier interval and confirm patch status. The blocked request cannot establish that previous attempts failed.

References: R17 and R18. Related cards: 31, 45 and 56.

23 Windows authentication event IDs

Check this first

Confirm provider Microsoft Windows Security Auditing and the Security channel. Event availability depends on audit policy and collection. Inspect account, source, destination, logon type, authentication package, status and logon ID.

Use these logs

Event	Meaning	First pivot
4624	Successful logon	Type and source
4625	Failed logon	Status and substatus
4634 and 4647	Session end or user logoff	Same logon ID
4648	Explicit credentials used	Target and process
4672	Special privileges at logon	Account and session
4768 and 4769	Kerberos TGT or service ticket	Client and service
4771 and 4776	Kerberos failure or NTLM validation	Failure and source

Use these tools

Use native XML when the SIEM omits fields. Join logon IDs only within the correct computer and context. Domain-controller ticket events and destination-host logons describe different stages.

Useful logon types include 2 interactive, 3 network, 4 batch, 5 service, 7 unlock, 9 new credentials, 10 remote interactive and 11 cached interactive. Type 3 is not automatically lateral movement.

23 Decisions and response

What the result means

4624 means a logon succeeded, not that a human was authorised. 4672 is common for expected privileged services. 4648 can arise from legitimate run-as or automation. A 4769 service-ticket request does not by itself prove the service was accessed.

Take this action

Build a sequence of failures, success and subsequent resource use. Compare source device, account role, normal schedule and expected authentication package. Inspect status fields rather than counting every failure as a wrong password.

For a remote logon, correlate destination-side events with source processes, VPN sessions and network activity. Check whether source IP is absent, loopback or translated. Preserve event version because field availability can change across Windows versions and updates.

Escalate when

A success follows suspicious failures, a privileged account uses an unexpected source, or the session creates services, tasks or other access. Escalate unexplained authentication to domain controllers and backup systems promptly.

Worked example

13:10:01 DC01 4771 user=maya failure=0x18

13:10:06 DC01 4771 user=maya failure=0x18

13:11:20 FS01 4624 user=maya type=3

These simplified records do not prove that the same actor caused all three events. Compare client addresses, session context and subsequent file access before linking them.

References: R11 and R12. Related cards: 28, 36, 37 and Appendix C.

24 Windows account and group changes

Check this first

Identify the subject that performed the change and the target account or group. Distinguish local SAM changes from domain changes. Compare the change with an approved request, exact group, intended membership and source device.

Use these logs

Event	Change to review
4720 and 4722	User created or enabled
4723 and 4724	Password change or reset attempt
4725 and 4726	User disabled or deleted
4738	User account changed
4728 and 4729	Global group member added or removed
4732 and 4733	Local group member added or removed
4756 and 4757	Universal group member added or removed
4719 and 1102	Audit policy changed or Security log cleared

Use these tools

Use native records and directory audit views. Track target SID/object ID, subject identity, group SID, computer and event time. A group with a familiar display name may not be the intended group.

24 Decisions and response

What the result means

An administrator's involvement does not automatically legitimise a change. A help-desk workflow may explain a password reset, but not a new privileged membership. An attempted password reset event requires outcome review; its presence alone is not confirmation of success.

Take this action

Search the actor's preceding logon and following activity. Check whether the new account signed in, received other privileges or accessed critical resources. Review changes to authentication methods and cloud roles separately; Windows events do not capture every Entra operation.

If unauthorised, preserve the membership and audit state before approved reversal. Determine which access was exercised while the permission existed. Removing a role does not undo data access or automatically remove all sessions and secondary persistence.

Escalate when

The group grants administration, the actor is unexplained, a dormant account is re-enabled, or auditing is changed during suspicious activity. Treat role additions near log clearing as a linked investigation, not isolated tickets.

Worked example

An overnight 4732 event adds a service account to local Administrators on three workstations. The deployment ticket covers only one server. Validate the discrepancy, identify the initiating session and scope the three workstations before applying any exception.

Record requested and actual membership, actor, source, change approval and rollback verification. References: R11 and R12. Related cards: 19, 28, 39 and 55.

25 Process service and scheduled task events

Check this first

Look for execution mechanisms that survive a logoff or run with higher privilege. Capture the complete executable path, arguments, task XML or service configuration, run-as identity and creating process.

Use these logs

Event	Provider or channel context	Meaning
4688	Security Auditing	Process created
4689	Security Auditing	Process ended
4697	Security Auditing	Service installed
7045	Service Control Manager System	Service installed
4698 and 4702	Security Auditing	Task created or updated
4699 to 4701	Security Auditing	Task deleted enabled or disabled

Task Scheduler Operational records can show registration and execution when collected. Event 4688 command-line content requires the appropriate configuration; absence of a command line is not evidence of harmlessness.

Use these tools

Use EDR, native event XML and approved configuration exports. Join Security and System records by host, time and service details rather than expecting identical fields.

25 Decisions and response

What the result means

Task or service creation proves a configuration change, not that the configured action executed. A stopped task can still provide persistence. Legitimate software deployment can create similar records, so verify exact binary, signer, path and business purpose.

Take this action

Find the creator's logon session, originating host and preceding process chain. Check execution events for the configured binary. Review files in user-writable paths, UNC locations and unexpected interpreters. Search other systems for the same task action or service binary.

Preserve XML and configuration before removing unauthorised persistence. Then remove it through approved actions, verify absence and investigate how the creator obtained access. Do not delete a task simply because its name is unfamiliar.

Escalate when

The action runs as SYSTEM or a privileged account without approval, points to untrusted content, follows remote authentication or reappears after removal.

Worked example

```
13:21:00 WS017 4698 task=InventoryCheck  
action=C:\Users\Public\check.ps1  
13:22:00 WS017 4688 image=powershell.exe  
parent=taskeng.exe
```

The simplified records support task execution but not its purpose. Review the script, creator and network activity. A routine-sounding task name has little evidential value.

References: R04 and R11. Related cards: 20, 42 and 56.

26 Essential Sysmon events

Check this first

Confirm Sysmon is installed, healthy and configured to collect the event types needed. Sysmon is telemetry, not a verdict engine. Network and image-load collection are configuration-dependent and may be absent.

Use these logs

Event	Primary use
1	Process creation and ancestry
3	Process network connection
6 and 7	Driver and image loading
8 and 10	Remote thread and process access
11 and 15	File creation and named stream
12 to 14	Registry changes
19 to 21	WMI subscription components
22	DNS query
23 and 26	File deletion with or without archive
25	Process tampering

Use these tools

Use ProcessGuid to correlate related events. Record UtcTime, Computer, Image, User and relevant target fields. Include event 16 configuration changes and event 255 errors when investigating collection gaps.

26 Decisions and response

What the result means

Process access to LSASS is a lead that needs source, rights and call-context review. Security software can legitimately access sensitive processes. DNS events show queries, including unsuccessful ones; they do not prove a network session occurred.

Take this action

Start with a suspicious process creation and pivot to its network, file, registry and child-process records. Preserve GUIDs instead of using PID alone. Check rule filters and collection delay before interpreting absent events.

Record the deployed Sysmon configuration and collection period with the case. A configuration change midway through an investigation changes what negative searches can establish. Compare similar devices only when their telemetry coverage is comparable.

Escalate when

The same process shows suspicious access, persistence and external communications; the sensor is unexpectedly disabled; or critical hosts lack the telemetry needed to resolve an active incident.

Worked example

```
13:30:00 id=1 guid=P17 image=powershell.exe  
13:30:02 id=22 guid=P17 query=sync.example  
13:30:03 id=3 guid=P17 dst=198.51.100.24
```

The simplified sequence ties a lookup and connection to one process. Inspect its parent and script before deciding whether it is approved automation or malicious execution.

Reference: R03. Related cards: 20, 40, 43 and Appendix D.

27 PowerShell and AMSI logs

Check this first

Capture the original command, process ancestry, user and script path. Distinguish powershell.exe from pwsh.exe and check the relevant version and event channel. Look for download, decoding, credential access, persistence or remote execution behaviour.

- 4104 script-block records may contain the executed script text.
- 4103 module records depend on configured module logging.
- Transcription can record command activity but must have been enabled and retained.
- AMSI is an inspection interface used by security products; it is not one universal event log that contains every script.

Use these logs

EDR, 4688, Sysmon 1, PowerShell Operational and security-product detections. Reassemble fragmented script blocks by their identifiers and sequence fields when necessary.

Use these tools

Decode only in an isolated local environment. Windows PowerShell EncodedCommand commonly uses Base64 of UTF-16LE text. Other encodings and wrappers exist; inspect rather than assume.

```
base64 --decode evidence/encoded.txt \  
| iconv -f UTF-16LE -t UTF-8
```

This prints decoded text. Never pipe it into PowerShell, bash or another interpreter.

27 Decisions and response

What the result means

Encoding, hidden-window options or an execution-policy argument are not individually proof of malware. Execution policy is not a complete security boundary. An AMSI detection may indicate prevention, but inspect the product's action result and earlier execution.

Take this action

Read the script's data sources, destinations and intended effects. Extract indicators to a separate worksheet and search related processes and hosts. Preserve original text, decoded text and transformation steps. Do not alter the raw evidence.

Check for human-assisted execution: a browser or chat message may instruct the user to paste a command. Ask what the user saw through a trusted channel, and corroborate with browser and process records. Avoid asking the user to repeat the action.

Escalate when

The script accesses credentials, disables controls, creates persistence or communicates with suspicious infrastructure. Escalate obfuscation beyond safe triage capability to malware or incident-response specialists.

Worked example

An encoded command decodes to an inventory query and a known internal management endpoint. Confirm the script signer, deployment owner and schedule. Another encoded command on the same host may still require independent review; do not allowlist the interpreter.

References: R04 and R13. Related cards: 20, 40, 48 and 53.

28 Active Directory and Entra ID logs

Check this first

Separate on-premises authentication from cloud identity activity. Resolve the same person across account identifiers without assuming every display-name match is the same identity. Check whether the identity is synced, cloud-only, guest or workload-based.

- AD: logon source, Kerberos/NTLM, group change and directory modification.
- Entra: interactive and non-interactive sign-ins, service-principal activity, audit operations and risk context.
- Review MFA method changes, role assignments and application credentials.
- Determine whether Conditional Access actually applied and why.

Use these logs

DC Security records, target-host logons, Entra sign-in and audit exports, application logs and endpoint sessions. Review resource-specific access after authentication.

Use these tools

In Log Analytics, SigninLogs commonly uses ResultType "0" for success. This query requires that table to be connected:

```
SigninLogs
| where TimeGenerated > ago(24h)
| where UserPrincipalName =~ "maya@example.com"
| project TimeGenerated, IPAddress,
  AppDisplayName, ResultType
```

A query over SigninLogs alone does not cover every non-interactive or workload identity record.

28 Decisions and response

What the result means

MFA satisfied does not always mean a fresh prompt occurred. An unfamiliar IP can be a proxy or cloud service. A risk label is an input to investigation; the user's actual actions and session evidence still matter.

Take this action

Read authentication details, device context and the target resource. Compare the suspicious session with normal behaviour and then review consent, directory, mailbox and file actions. Retrieve non-interactive and service-principal records separately where relevant.

For hybrid compromise, coordinate both directory and cloud containment. Determine whether credentials, refresh tokens, application secrets or federated trust are affected. Avoid broad disabling of sync or federation components without the incident commander's decision and recovery plan.

Escalate when

A privileged identity is used unexpectedly, a new authentication method is registered without approval, a workload secret is added, or cloud activity persists after the first containment attempt.

Worked example

A successful sign-in uses a previously satisfied MFA claim. Three minutes later the account grants an unfamiliar app access to mail. The MFA field cannot resolve whether that grant was authorised; investigate the session and consent together.

References: R05, R06 and R10. Related cards: 19, 37, 38 and 39.

29 Email and Microsoft 365 logs

Check this first

Identify the message, mailbox, user session and workload. Mail delivery, mailbox access and identity authentication are different evidence streams. Preserve stable message identifiers and the original message before any purge.

- Message trace: route, recipients and delivery outcome.
- Mailbox audit: rules, forwarding, delegates and sending activity.
- SharePoint/OneDrive: file access, downloads and sharing changes.
- Teams: messaging, external collaboration and file-sharing context.
- Entra: sign-ins, consent and directory changes.

Use these logs

Use the tenant's available audit and security records. Licensing, configuration and retention affect which events exist. Search operation names in the current provider documentation rather than assuming a universal schema.

Use these tools

Use approved message trace, audit search and threat investigation consoles. Search by message ID, recipient, sender, URL or file hash as appropriate. Save the query's filters and tenant time zone.

Useful operations can include New-InboxRule, Set-InboxRule, Set-Mailbox and MailItemsAccessed, subject to workload and audit availability. Data-access counts need careful interpretation.

29 Decisions and response

What the result means

A successful send does not prove the recipient read it. A file-access audit event does not always prove a human downloaded and reviewed a whole document. Some mailbox events aggregate activity. A deleted rule may have been active long enough to forward sensitive mail.

Take this action

Follow the sequence: suspicious authentication, mailbox or sharing change, access, sending and external destinations. Determine whether the account used delegated permissions or an application. Search activity before and after containment and include mobile or desktop clients.

Preserve permission and rule state before approved removal. Review sent, deleted and recoverable items through authorised workflows. Avoid changing mailbox settings during evidence collection unless containment requires it and the action is logged.

Escalate when

External forwarding, unexpected delegates, mass downloads, unauthorised sending or suspicious app access involves sensitive business data. Involve privacy and business owners through the incident process.

Worked example

A new rule moves finance messages to a hidden folder while forwarding externally. The identity owner denies it. Preserve the rule, revoke the relevant access, remove the rule with approval and scope messages potentially forwarded during its active period.

Reference: R10. Related cards: 18, 35, 39 and 57.

30 EDR process file and network telemetry

Check this first

Confirm device identity, sensor health, alert time and action status.

Identify whether the product observed, prevented, quarantined, killed or isolated something. These outcomes are not interchangeable.

- Capture the full process ancestry and relevant command lines.
- Map files created, renamed, deleted or loaded.
- Inspect network destinations with process attribution.
- Review persistence and credential-access indicators.
- Note collection gaps and retention limits.

Use these logs

EDR raw events, alert evidence, response audit and native host records.

A product's incident graph is a useful lead but may omit events outside its grouping window.

Use these tools

Example for Microsoft Defender advanced hunting, not generic Sentinel tables:

```
DeviceProcessEvents  
| where Timestamp > ago(24h)  
| where DeviceName =~ "ws017.example.com"  
| project Timestamp, FileName,  
    ProcessCommandLine,  
    InitiatingProcessFileName
```

Adapt the device and time range to authorised scope. Other products use different fields and retention.

30 Decisions and response

What the result means

A prevention action on one child process does not establish that its parent did nothing. Quarantine may fail if the device is offline or the file moved. A benign-looking parent can be injected into or used to launch malicious content.

Take this action

Reconstruct the chain and check the action result. Search related files, hashes, users and destinations across the estate. Compare process start times and unique process identifiers; do not join solely on PID.

If response is authorised, verify the device received and completed the action. Preserve relevant telemetry before reimaging or cleanup. Treat the endpoint and associated accounts as separate containment targets. Confirm that the sensor continues reporting after recovery.

Escalate when

Multiple devices show the same chain, the process accesses credentials, protection is tampered with, or a critical server needs isolation. Escalate inability to collect evidence from a high-risk device.

Worked example

EDR reports a malicious child blocked. The parent already wrote a scheduled task and contacted an external host. Continue the incident investigation because the prevention event does not undo those earlier actions.

Reference: R07. Record action requested, result, time, process chain and remaining questions. Related cards: 20, 21, 41 and 56.

31 Firewall proxy DNS and VPN logs

Check this first

Identify the device producing the record and what its fields actually mean. Determine direction and whether addresses are original, translated or proxy-facing. An action named accept may describe policy permission rather than completed application activity.

- Firewall: session, ports, action, bytes and reason.
- Proxy: user, hostname, URL, method, status and policy.
- DNS: client, query, response, result and resolver.
- VPN: identity, source, assigned address, authentication and session.
- WAF/IPS: signature, rule mode, target and enforcement result.

Use these logs

Correlate network records with endpoint and application telemetry. Preserve NAT and VPN allocation history for the incident period. Check log sampling, aggregation and session-end behaviour.

Use these tools

Use vendor field documentation and SIEM raw payloads. Record which side initiates each connection. Do not use country, port or reverse DNS as an identity verdict.

Search both original and translated addresses when investigating a path through multiple controls.

31 Decisions and response

What the result means

HTTP 200 does not prove successful exploitation; application response content and subsequent activity matter. DNS resolution does not prove connection. An outbound byte count does not prove sensitive-data exfiltration. TLS encryption may hide the content while preserving useful timing and endpoint context.

Take this action

Build the path from user or process to resolver, proxy/firewall and application. Check earlier and alternate routes when a control blocked one request. Review destination rarity, periodicity and data volume against similar devices.

Before blocking, assess whether the indicator is a shared CDN, resolver, mail relay or critical service. Use the narrowest supported control and define review or expiry. Preserve the evidence used to justify the decision.

Escalate when

Permitted traffic links to suspicious execution, remote access uses a stolen identity, or an exposed service shows post-exploitation changes. Escalate missing NAT or VPN records that prevent attribution during an active incident.

Worked example

A proxy shows a file download from a cloud-sharing platform. The domain is legitimate, but EDR links the downloaded shortcut to script execution. Investigate the object and process chain rather than allowlisting the entire platform.

Related cards: 13, 14, 44, 45 and 46.

32 Linux and cloud audit logs

Check this first

Identify the Linux distribution, logging configuration, cloud tenant/account and affected resource. A local shell command and a cloud API request require different attribution. Check audit availability before interpreting an empty search.

- Linux: SSH, sudo, authentication, journald, auditd, cron and systemd.
- AWS: CloudTrail management events, assumed roles and separately configured data events.
- Azure: Activity Log for resource management plus Entra and resource-specific logs.
- Google Cloud: Admin Activity and relevant Data Access audit records.

Use these logs

Capture principal, source, action, target, result, request ID and time. AWS management-event visibility is not a complete record of object access. Cloud data-access logging depends on service, configuration and retention.

Use these tools

Read-only Linux examples, subject to approved access:

```
journalctl --utc --since '2026-09-25 00:00:00'  
journalctl -u ssh --utc
```

The SSH unit may be sshd instead of ssh. Native logs may also be in auth.log or secure, depending on the distribution.

32 Decisions and response

What the result means

A successful SSH session can be authorised administration or compromised access. Shell history is incomplete and alterable. A cloud API success may be automated activity, so inspect the role, session issuer, workload and change context.

Take this action

Trace SSH logon to sudo and process activity. Review new authorised keys, scheduled jobs and service units using approved collection. In cloud investigations, follow role assumption, credential creation, policy changes, storage access and logging changes.

Separate management-plane actions from data-plane impact. If data-access logs were not enabled, document that gap and use available application, storage or billing evidence without claiming a complete access history. Preserve logs in a location the suspected principal cannot alter.

Escalate when

Root or cloud-administrator access is unexplained, keys or policies change, logging stops, public exposure appears or sensitive resources are accessed. Involve the platform owner before disabling production workload identities.

Worked example

A new access key is created, then used to change a storage policy. Management events support the configuration change. Whether objects were read requires the relevant data-access telemetry; do not infer a complete data-theft conclusion from the policy event alone.

References: R19 and R20. Related cards: 19, 39, 46 and 55.

33 Phishing email

Check this first

Preserve the original message and determine interaction before deciding severity. Record whether it was blocked, delivered, viewed, clicked, used to submit credentials or followed by execution. Ask the user through a trusted channel; do not ask them to reopen the link.

- Validate sender route and authentication results.
- Inspect the requested action and any urgency or impersonation.
- Search all recipients and variants of the campaign.
- Distinguish automated link scanning from human interaction.
- Check whether the message came from a compromised legitimate account.

Use these logs

Email gateway, message trace, click protection, DNS, proxy, browser, identity and EDR. Preserve message IDs, URLs and attachment hashes. An email deletion alone does not resolve an identity or endpoint compromise.

Use these tools

Use internal message analysis first. Search existing URL and hash intelligence. Use approved private analysis for sensitive content. URLhaus focuses on malware-delivery URLs; lack of a result does not clear credential phishing.

Create an interaction matrix with one row per recipient and columns for delivered, clicked, credentials entered, file executed and evidence source.

33 Decisions and response

What the result means

A familiar sender or authentication pass does not prove legitimacy. Grammar quality is not a dependable signal, especially when messages are professionally written or AI-assisted. A scan result may reflect content different from what the user saw.

Take this action

Preserve, scope and then remove or block the malicious message using approved controls. If credentials were entered, use card 55. If execution occurred, use card 56. If only delivery is established, assess user exposure without claiming compromise.

Search for related messages using more than the exact subject. Attackers can vary wording while reusing URLs, attachments or infrastructure. Record purge success, failures and users who may still have offline copies.

Escalate when

There is credential disclosure, executable content, an executive or finance target, widespread delivery, or evidence that the sender is internally compromised.

Worked example

```
09:00 mail delivered recipients=12
09:07 click user=maya device=WS017
09:08 identity new_session user=maya
09:11 mailbox new_forwarding_rule
```

This fictional sequence supports urgent identity investigation. Verify the click was human and connect the session to the mailbox action before reporting confirmed account compromise.

Closure requires documented recipient scope, interaction assessment, verified removal or blocking and completed related identity/endpoint work. Related cards: 15, 18 and 57.

34 Malicious link or attachment

Check this first

Separate exposure from execution. A user can download an attachment without running it, or execute a pasted command without downloading a traditional executable. Preserve the original link or attachment and the delivery context.

- Identify file type, extracted contents and true extension.
- Review browser, archive utility and document-reader children.
- Check shortcuts, scripts, HTML files and password-protected archives.
- Determine whether credentials were entered or commands copied.
- Review whether prevention happened before or after execution.

Use these logs

Mail or collaboration delivery, browser downloads, proxy, EDR process/file/network telemetry, PowerShell logs and identity sign-ins. Include Teams, Slack and cloud-sharing delivery where relevant.

Use these tools

Use local hashing and static inspection on copies. Search hashes before upload. Use an isolated approved sandbox only when it answers a specific unresolved question and confidentiality permits.

Do not extract suspicious archives to shared folders or enable document content to see what happens.

34 Decisions and response

What the result means

A filename ending in .pdf can hide a shortcut when extensions are concealed. A password-protected archive can evade some gateway inspection, but the archive itself is not proof of malware. A link to a trusted platform can still point to an attacker-controlled object.

Take this action

Trace delivery to save, open, child process and network action. Search related hashes, filenames and delivery URLs across all recipients. If execution is credible, preserve evidence and request endpoint containment according to local authority.

If the user entered credentials or granted access, investigate identity separately. If execution was blocked, verify the exact action result and review earlier children or persisted artefacts. Quarantine does not retrospectively undo actions already completed.

Escalate when

Script execution, persistence, credential access or external command traffic occurs; a trusted software package is implicated; or several users received the same content.

Worked example

```
10:01 Teams file=Cases.zip recipient=maya  
10:04 explorer opens Cases.pdf.lnk  
10:04 powershell child of explorer  
10:05 process connects to external host
```

The fictional chain warrants endpoint and identity scoping. The use of a legitimate collaboration platform does not make the content trusted.

Record exposure stage, process chain, affected recipients and response results. Related cards: 16, 17, 40 and 56.

35 Business email compromise

Check this first

Identify the business transaction: payment change, invoice, payroll, confidential data or executive instruction. Determine whether funds moved or data was released. Notify the authorised finance or fraud contact promptly when a transaction may still be stopped.

- Preserve the full email thread and original headers.
- Compare sender, reply-to and account details with trusted records.
- Confirm changes through a known independent phone number or workflow.
- Check mailbox rules, delegates, sending and sign-ins.
- Review whether an internal or vendor mailbox may be compromised.

Use these logs

Email trace, mailbox audit, identity sessions, finance workflow and approved transaction records. Request only the financial or personal information needed for the investigation and store it with restricted access.

Use these tools

Use the internal case system and verified vendor contacts. Do not validate bank changes using contact details supplied in the suspicious message. Malware scanners alone do not resolve BEC.

Treat deepfake voice or video as an additional reason to use established verification procedures, not as conclusive proof either way.

35 Decisions and response

What the result means

BEC may involve no malicious link or file. A genuine mailbox can pass email authentication and still send fraudulent instructions. A fraudulent message does not automatically mean the recipient's account is compromised.

Take this action

Coordinate transaction hold or recall through authorised finance processes. Preserve mailbox and identity evidence, then contain confirmed unauthorised access. Review forwarding, delegates, OAuth permissions and altered rules. Scope messages and sensitive data exposed during the affected period.

Contact the vendor through a previously verified channel if its account may be compromised. Keep accusations and attribution provisional until supported. Legal, privacy and external notifications belong to designated owners under applicable policy.

Escalate when

Money moved, sensitive information was sent, privileged mailboxes are involved or the adversary is actively replying. Treat payment recovery as time-sensitive even while technical investigation continues.

Worked example

A supplier thread requests a new payment account. The real supplier confirms the change is fraudulent. No malware exists in the message. Finance holds payment while the SOC investigates sender history, internal recipient activity and possible mailbox access.

Closure requires finance/fraud confirmation of the transaction outcome, identity containment where applicable, evidence of rule cleanup and a documented exposure assessment. Related cards: 18, 29 and 57.

36 Brute force and password spraying

Check this first

Determine the pattern. Brute force commonly targets one or a few accounts with many attempts. Password spraying commonly tries a small password set across many accounts. Credential stuffing reuses exposed credential pairs. Real campaigns may blend patterns and spread sources over time.

- Count distinct users, source addresses and target applications.
- Read failure reasons, not only failure counts.
- Search successful sign-ins during and after the failures.
- Compare with stale service credentials, scanners and user mistakes.
- Check whether the activity is still occurring.

Use these logs

Windows 4625, 4771 and 4776, Entra sign-ins, VPN, application authentication and account lockouts. For Windows, inspect status/substatus; for cloud services, use the documented result code.

Use these tools

Use a time-bounded aggregation and then inspect raw samples. Thresholds must be tuned to local behaviour. Search across longer windows for low-and-slow spraying, not just a five-minute burst.

Separate interactive users from expected service accounts to avoid hiding distinct patterns inside one count.

36 Decisions and response

What the result means

Many failures do not prove that any password was guessed. A subsequent success may be the legitimate user, so compare source, device, method and downstream actions. Lockouts can themselves disrupt service and should be assessed as impact.

Take this action

Scope targeted identities, especially privileged and inactive accounts. Review successful sessions and any mailbox, role or data-access changes. Coordinate rate limiting, network controls and identity protections with the owning teams.

Avoid indiscriminately disabling all targeted accounts or blocking a shared corporate egress address. If credentials are confirmed exposed, follow the identity-compromise process and review related services. Retain a query for the entire campaign window.

Escalate when

Any suspicious success is followed by unauthorised activity, privileged users are targeted, lockouts affect production or the attack overwhelms authentication services.

Worked example

```
11:00-11:10 src=198.51.100.24 users=43 failures=86  
11:12 user=svc_backup result=success  
11:15 actor=svc_backup target=backup-console
```

The fictional success on a sensitive service account needs immediate validation and downstream review. Do not infer compromise solely from the aggregate.

Related cards: 23, 28, 37 and 55.

37 Suspicious successful login

Check this first

Confirm what succeeded: authentication, session creation or resource access. Resolve the account, device, application and session. Ask the owner through an independently trusted channel whether the specific activity was expected.

- Compare source ASN, device, browser/client and normal schedule.
- Check interactive versus non-interactive sign-in.
- Review MFA details and Conditional Access outcome.
- Search preceding failures and changes to recovery methods.
- Inspect what the session did after authentication.

Use these logs

Entra or other identity-provider records, destination application logs, VPN sessions, endpoint logons, mailbox audit and cloud API activity. A success at the identity provider may still be followed by application denial.

Use these tools

Use session/correlation IDs where supported and compare stable device identifiers. IP geography is context, not identity. Avoid treating a new user agent as definitive because updates and proxies can change it.

Document the owner response with time and verification method, not simply "user confirmed".

37 Decisions and response

What the result means

A successful logon with valid credentials can be malicious. A new country can be legitimate VPN use. An owner denial is important but must be reconciled with service automation and delegated access. A stolen cookie can reuse an already authenticated session.

Take this action

Review post-login activity for high-value changes and data access. Determine whether the same identity appears from incompatible devices or concurrent contexts. Preserve the session evidence before approved revocation or account restrictions.

If compromise is suspected, review MFA registration, consent, mailbox rules and application credentials. Search for additional affected identities on the source device. The login may be a symptom of an infostealer on a different endpoint.

Escalate when

The owner denies an active session, a privileged resource is accessed, sensitive data is retrieved, or suspicious activity continues after revocation. Coordinate identity and endpoint response.

Worked example

A dormant account signs in and immediately creates a forwarding rule. The owner left the organisation and the account should be disabled. Preserve the audit trail, involve the identity owner, contain access and investigate who re-enabled or retained the account.

Closure requires an explained session or verified containment, downstream scope and documented access changes. References: R05 and R06. Related cards: 19, 38 and 55.

38 Impossible travel MFA fatigue and token replay

Check this first

Treat these as distinct hypotheses. Impossible travel is an anomaly in apparent location or timing. MFA fatigue is repeated prompting intended to obtain approval. Token replay uses stolen session material and may not require a fresh password or prompt.

- Verify event times, IP ownership, VPN exits and mobile-carrier effects.
- Review whether MFA was actually challenged or satisfied by an existing claim.
- Check user reports of unexpected prompts or device-code requests.
- Review device/session changes and concurrent activity.
- Look for phishing, browser compromise and infostealer evidence.

Use these logs

Identity sign-ins, authentication details, Conditional Access, token/session context where available, endpoint and application audit. Not every tenant exposes all token-related fields.

Use these tools

Use the identity provider's session view and application logs. Do not replay captured tokens to test them. Keep any tokens in restricted evidence storage; they can provide active access.

Use phishing-resistant authentication guidance for recovery planning, but do not assume any control eliminates every session-theft scenario.

38 Decisions and response

What the result means

Two distant IPs do not prove two humans or an attacker. Conversely, a familiar IP and MFA-satisfied result do not prove that the legitimate user controlled the session. Geography alone cannot distinguish these cases.

Take this action

Investigate what each session did, its device context and whether the owner recognises the action. For suspected compromise, coordinate session revocation, credential changes where needed, MFA re-registration and endpoint assessment. Remove unauthorised application grants and persistence separately.

Verify revocation behaviour in each affected application. Existing access tokens or application sessions may remain valid depending on enforcement and provider design. Continue monitoring and restrict the account if activity persists, following authorised procedures.

Escalate when

An unexpected approval is followed by successful access, a denied user action has evidence of token reuse, or high-value application activity continues after containment.

Worked example

The user reports repeated prompts, denies approving them, but the record shows a successful session and mailbox export. Validate the authentication sequence and export operation. Preserve the evidence and start identity containment; do not dismiss it because MFA appears in the record.

References: R05 and R06. Related cards: 15, 19, 28 and 55.

39 New administrator or suspicious OAuth application

Check this first

Determine whether the alert concerns directory role assignment, local group membership, app consent, service-principal creation or application credentials. These grant different kinds of access and require different reversal steps.

- Identify actor, target, role/permission, scope and result.
- Verify exact approval and change window.
- Review requested permissions and tenant-wide versus user consent.
- Check new secrets, certificates, redirect URIs and owners.
- Search API or resource actions after the change.

Use these logs

Directory audit, AD group changes, PIM/PAM history, service-principal sign-ins, application consent and target-resource audit. A newly visible application may have existed elsewhere before installation in the tenant.

Use these tools

Use native identity administration and audit exports. Preserve object IDs and permission details. Publisher verification or a familiar name helps context but does not by itself establish that access was authorised.

For service identities, involve the application owner before disabling production access.

39 Decisions and response

What the result means

Removing a user's password access does not automatically remove an app grant or a newly added credential. An administrator role may have been used to create additional access before it was removed. Scope the actions, not just the original change.

Take this action

Preserve the current configuration and audit trail. If unauthorised, coordinate removal of the exact role, grant or credential and revoke relevant sessions. Review affected resources, data access and secondary accounts or keys. Verify the remediation succeeded.

Search the same initiating identity and source across the tenant. Review whether an existing legitimate application was modified rather than assuming only newly created apps are risky. Maintain a rollback plan for necessary business applications.

Escalate when

Tenant-wide consent, privileged roles, broad mail/file permissions, new workload secrets or unexplained policy changes occur. Treat abuse of emergency accounts as urgent.

Worked example

```
12:01 actor=maya action=consent scope=Mail.Read  
12:04 app=UnapprovedSync action=mail_access  
12:08 actor=maya action=add_app_secret
```

The fictional sequence requires consent and credential review plus access scoping. Password reset alone would leave the application changes unresolved.

References: R05 and R10. Related cards: 24, 28 and 55.

40 Suspicious PowerShell or script execution

Check this first

Preserve original command line, script text, process ancestry, user, device and time. Determine whether execution came from management software, a document, a shortcut, a browser instruction or remote access.

- Identify download, decoding, persistence and credential-access behaviour.
- Check script signature and approved deployment context.
- Review child processes and network destinations.
- Inspect the control's actual prevention result.
- Search related executions across users and hosts.

Use these logs

PowerShell 4104/4103 where enabled, EDR, 4688, Sysmon, proxy/DNS, file events and remote-session records. Retrieve native events if the SIEM truncates long commands.

Use these tools

Use local CyberChef or a controlled offline decoder. Reconstruct layered text without executing it. Use the PowerShell card for UTF-16LE decoding and the process card for ancestry.

Never copy a suspicious command directly into a console or ask the affected user to run it again. Preserve script blocks that contain sensitive data in restricted evidence storage.

40 Decisions and response

What the result means

Encoding and unusual flags are signals, not verdicts. Legitimate software can use them. Stronger evidence comes from delivery context and effects such as external retrieval, credential access, persistence or unexpected administrative changes.

Take this action

Trace the script's inputs and outputs. Identify URLs, file paths, registry keys, accounts and scheduled actions. Scope them across the environment. If execution is malicious or strongly suspected, request authorised endpoint containment and assess identities used on the device.

Preserve decoded text alongside the original and state each transformation. Stop analysis when dynamic behaviour or anti-analysis exceeds the safe local workflow and escalate to specialists. Do not attempt to bypass protection to make the sample run.

Escalate when

The script accesses sensitive memory, disables controls, creates persistence, runs as a privileged identity or contacts command infrastructure. Escalate a user-executed browser instruction even if no attachment exists.

Worked example

13:02 browser page asks user to paste a command
13:03 explorer launches powershell.exe
13:03 script writes file under user profile
13:04 new scheduled task references that file

The fictional chain supports user-assisted execution and persistence. Confirm task execution and external traffic to establish further impact.

Reference: R13. Related cards: 20, 27, 42 and 56.

41 Suspicious process tree or LOLBin

Check this first

Determine why a legitimate utility appears in an unusual context. A living-off-the-land binary is not inherently malicious. Investigate the supplied arguments, content source, parent, privilege and resulting behaviour.

- Validate the executable path, signer and hash.
- Identify document, browser, mail-client or service ancestry.
- Review remote content, user-writable paths and unexpected child processes.
- Check network, registry, file and credential-access effects.
- Compare with documented administration or software installation.

Use these logs

EDR process graphs, 4688, Sysmon, script logs and application telemetry. Join processes using stable identifiers and start times. Parent information can be incomplete or manipulated; corroborate important relationships.

Use these tools

Use LOLBAS for Windows and GTF0Bins for Unix-like utilities as behaviour references. Search the observed binary and function, then return to the actual command. Do not run catalogue examples on production.

Useful pairs to investigate include office applications to shells, web services to interpreters and archive utilities followed by shortcut-driven execution.

41 Decisions and response

What the result means

A trusted signature establishes signing information, not benign intent. A common process can load an untrusted DLL or execute attacker-controlled data. An unusual parent-child pair can also be a legitimate installer or support workflow.

Take this action

Reconstruct the complete chain and verify the claimed business activity. Review paths, content origin and execution result. Search equivalent behaviour across the estate, including renamed copies and alternate interpreters.

For suspected injection, examine available process-access, thread, module and tampering telemetry. Do not assume a process with a familiar name is the original trusted image. Preserve evidence and ask a specialist when memory analysis is required.

Escalate when

The process chain includes credential access, persistence, unexpected privilege or external command traffic. Escalate web-server-to-shell execution promptly on an exposed system.

Worked example

```
parent=w3wp.exe child=cmd.exe user=app_pool  
child writes C:\ProgramData\cache.bin  
child connects to 198.51.100.24
```

The fictional chain is inconsistent with many normal web workloads, but establish the application context and change history. Investigate possible server compromise rather than attributing a malware family from the process name.

References: R03, R07 and R25. Related cards: 20, 40, 45 and Appendix E.

42 New service scheduled task or persistence

Check this first

Capture the persistence mechanism before removal. Record task XML, service configuration, registry value, WMI subscription or other startup artefact. Identify the creator, run-as account, trigger and executable content.

- Check creation and update time against the change record.
- Inspect the full action, including arguments and working directory.
- Identify user-writable paths, remote shares and unknown interpreters.
- Determine whether execution occurred and under which identity.
- Search peers for the same mechanism and payload.

Use these logs

4697/7045 for services, 4698/4702 for tasks, Sysmon registry and WMI events, EDR and native configuration exports. Linux equivalents include cron, systemd and authorised-key changes; investigate the applicable platform.

Use these tools

Use approved read-only collection through EDR or native administrative tools. Preserve a copy before approved removal. A read operation can still leave access traces; record collection activity.

Compare configuration with a trusted baseline rather than relying on a legitimate-looking task or service name.

42 Decisions and response

What the result means

Persistence registration does not prove successful execution. Removing one mechanism does not eliminate secondary access. A recreated task can indicate an active operator, a watchdog or an unresolved legitimate deployment agent.

Take this action

Trace the creator back to a session and access path. Review the payload's process, file and network activity. If malicious, coordinate containment first when needed, then remove the artefact and verify it remains absent.

Search for alternate persistence using the same identity or payload. Review affected accounts and software distribution paths. Record rollback information for business services, but do not restore a suspicious configuration until the owner validates it.

Escalate when

Persistence runs with elevated privilege, appears on several hosts, targets a critical server or returns after removal. Escalate changes created through a compromised administration platform.

Worked example

A task called UpdateCheck runs a script from a user's temporary directory every ten minutes. The user denies creating it and the script connects externally. Preserve the XML and script, scope previous runs, contain the host and investigate the originating session before deleting the task.

Closure requires removal verification, access-path remediation and monitoring across the relevant trigger interval. Related cards: 25, 26, 40 and 56.

43 Credential dumping and LSASS access

Check this first

Determine what the sensor observed: process access, memory read, dump-file creation, registry-hive access or a product-specific detection. Identify the source process, target, access rights, signer, parent and user.

- Review whether approved security or diagnostic software explains the access.
- Look for dump files and subsequent compression or transfer.
- Check local and domain accounts active on the host.
- Review suspicious logons and remote access after the event.
- Preserve volatile evidence through trained responders when needed.

Use these logs

EDR detections, Sysmon 10 and process telemetry, file creation, Security events and authentication records. Sysmon ProcessAccess does not record every possible credential-theft method. Lack of an event cannot clear the host.

Use these tools

Use the product's evidence and an approved forensic workflow. Do not reproduce credential dumping to validate the alert. Treat collected dumps and credential material as highly restricted evidence.

Check whether the control prevented the action or only detected it, and whether earlier access could have succeeded.

43 Decisions and response

What the result means

LSASS access by itself is not definitive credential theft. Security agents and diagnostics may legitimately interact with it. Stronger evidence includes an unusual source, sensitive access pattern, dump artefact and subsequent unauthorised authentication.

Take this action

Contain the affected host when justified and authorised. Scope identities potentially exposed, including administrators and service accounts. Coordinate credential rotation in a safe order with identity and application owners. A blanket reset without dependency planning can disrupt production.

Search for lateral movement and use of compromised accounts on other devices. Preserve forensic evidence before cleanup when feasible. High-impact domain recovery, such as trust-secret operations, requires the identity response team and an approved recovery plan.

Escalate when

Credential extraction is confirmed or strongly supported, privileged accounts were present, multiple hosts are involved or domain-control infrastructure may be affected. Treat potential exposure of backup administrators as urgent.

Worked example

An unsigned process in a temporary directory accesses LSASS, creates a large dump file and is followed by a remote service installation on another host using an administrator account. The linked evidence supports incident escalation and identity scoping beyond the first device.

Related cards: 23, 26, 41, 55 and 56.

44 Suspicious DNS beaconing or command and control

Check this first

Identify the initiating device and process, then measure the pattern. Repeated connections may be a management agent, telemetry, scheduled job or malicious beacon. Rarity and timing need context.

- Check destination, domain, port and protocol.
- Review interval variation, connection duration and bytes.
- Inspect DNS query length, response pattern and error rate.
- Compare with peer devices and approved software.
- Search for delivery, execution and persistence before the network activity.

Use these logs

DNS, proxy, firewall flows, EDR network/process events and available PCAP. DNS-over-HTTPS or encrypted client hello can reduce network visibility; record the actual sensor coverage rather than assuming every hostname is visible.

Use these tools

Use internal baselines, existing reputation and passive DNS. For captured traffic, use Wireshark/TShark and Zeek offline. Do not connect to suspected command infrastructure to see whether it responds.

Measure the sequence using event times, not ingestion times, and account for proxy or sensor aggregation.

44 Decisions and response

What the result means

Regular timing is not proof of command and control. Long DNS labels may reflect legitimate services. A known malicious destination is stronger when tied to unexpected execution. Encrypted traffic can support timing and process analysis without revealing content.

Take this action

Correlate network activity with the process chain and file or registry changes. Search the destination and equivalent behaviour across hosts. Investigate whether a legitimate remote-management tool is used by an unauthorised operator.

If blocking is approved, assess shared infrastructure and preserve before/after evidence. Endpoint isolation may be safer than blocking a widely used cloud platform. Continue looking for alternate destinations and identities after the first channel is interrupted.

Escalate when

A suspicious process generates the traffic, commands or payloads are observed, activity spans several hosts, or the destination follows credential access or persistence.

Worked example

```
13:00:00 WS017 -> sync.example 443 512 bytes  
13:01:01 WS017 -> sync.example 443 508 bytes  
13:02:00 WS017 -> sync.example 443 515 bytes  
process=unapproved script interpreter
```

The fictional pattern warrants investigation. Compare with the script's origin and content before concluding that every regular connection is malicious.

Related cards: 13, 14, 31, 40 and 51.

45 Port scan exploitation or WAF alert

Check this first

Determine whether the activity is reconnaissance, an exploit attempt or supported compromise. Confirm the target service, vulnerability applicability, rule mode and enforcement outcome. A signature match alone is not proof of successful exploitation.

- Check scanner identity and approved testing windows.
- Validate destination ownership and actual exposure.
- Review request, response and application behaviour.
- Search process creation, file changes, new accounts and outbound traffic.
- Check alternate routes that bypass the WAF or IPS.

Use these logs

WAF/IPS, firewall, load balancer, application access/error logs, EDR and configuration audit. Confirm the true client address using trusted proxy headers and topology; arbitrary forwarded headers can be spoofed.

Use these tools

Use vendor advisories and passive service intelligence. Authorised asset validation may use approved scanning, but do not run exploit scripts against production merely because an alert fired.

Record whether the detection was in monitor-only mode and whether the vulnerable feature was reachable.

45 Decisions and response

What the result means

HTTP success is not proof of exploitation, and an error response is not proof of failure. An exploit can perform an action before returning an error. A web shell may appear as ordinary HTTP traffic; host and application evidence are essential.

Take this action

Search before the first alert and after the request for post-exploitation changes. Compare affected versions with the vendor advisory. Preserve application logs before rotation and snapshot or collect the system through authorised forensic procedures when appropriate.

For confirmed compromise, contain with the service owner, remove the access path and investigate persistence. Patching alone may leave an existing web shell or stolen credential usable. Verify remediation and deployment integrity before returning to normal operation.

Escalate when

An exposed critical service is vulnerable, a server launches a shell, new files or accounts appear, or outbound activity follows the request. Coordinate service disruption decisions with incident command.

Worked example

A WAF reports a blocked exploit request. Native server logs reveal a similar earlier request through a direct IP path, followed by a shell process. Treat the earlier route as potential compromise and investigate both network paths.

Related cards: 22, 31, 41 and 56.

46 Data staging and exfiltration

Check this first

Identify the data, actor, source system and destination. Separate data collection, staging, attempted transfer and confirmed transfer. Determine sensitivity and business ownership before stating impact.

- Look for unusual archive creation or bulk file reads.
- Check external uploads, sharing changes and email forwarding.
- Review legitimate backup, replication and reporting activity.
- Compare volume, timing and destination with baseline.
- Establish whether the destination is controlled or authorised.

Use these logs

EDR file/process telemetry, DLP, proxy/flow, storage and database audit, SaaS file activity, mailbox records and cloud data-access logs. Network bytes alone cannot identify the exact documents transferred.

Use these tools

Use approved data-access searches and protected manifests. Request only necessary content. Coordinate with data owners and privacy/legal responders if exposure is suspected.

Keep file counts, byte counts, unique objects and confirmed sensitive records separate. Retries and synchronisation can inflate network totals.

46 Decisions and response

What the result means

An archive in a temporary folder is a lead; it may be a legitimate export. A completed outbound connection does not prove sensitive data left. An audit record for a successful object download is stronger, but the meaning of each service's event must be understood.

Take this action

Link the collecting process or session to specific files and transfer activity. Preserve destination, object IDs and time windows. Contain the session, sharing link or egress path with approval while considering ongoing business use.

Scope what could have been accessed separately from what is confirmed transferred. State confidence and telemetry gaps. Do not reduce the exposure estimate solely because files were later deleted or a link was revoked; earlier access may still have occurred.

Escalate when

Sensitive data may have left approved control, an external share is active, an insider or privileged identity is involved, or transfer continues during investigation. Follow applicable notification procedures through designated owners.

Worked example

14:00 user=maya archive created size=420MB

14:04 proxy upload external_host bytes=438M

14:05 storage audit export complete

The fictional correlation supports transfer investigation. Confirm the archive contents and destination authorisation before claiming a specific number of exposed customer records.

Related cards: 29, 32, 54 and 60.

47 Ransomware and mass file modification

Check this first

Determine whether destructive activity is continuing and which services are affected. Mass writes can be migration or backup activity, but unexpected encryption, ransom notes, recovery interference and suspicious process chains require urgent action.

- Identify the active process and source of remote file writes.
- Check affected shares, endpoints, virtualisation and backup systems.
- Review compromised privileged identities and remote sessions.
- Capture available evidence without delaying necessary harm reduction.
- Notify the incident commander and system owners.

Use these logs

EDR, file-server audit, storage alerts, process/service records, backup-console audit, identity and network events. A file server may be encrypted remotely by another device; isolating only the file server may not stop the source.

Use these tools

Use approved isolation and network segmentation. Verify action results. Preserve a ransom note and representative encrypted files through trained responders. Do not run random decryptors or repair tools on original evidence.

Protect recovery infrastructure and administrative access as part of the same incident.

47 Decisions and response

What the result means

Encryption may be only one phase. Data theft, credential compromise and backup targeting can precede it. No ransom note does not rule out destructive malware. A stopped process does not establish that all attackers or persistence are gone.

Take this action

Contain affected hosts and remote-write sources using authorised emergency procedures. Restrict compromised identities and protect backups. Avoid routine reboot or power-off decisions without considering volatility and business safety; use the incident commander's approved emergency plan when network isolation is unavailable.

Preserve evidence and assess scope before restoration. Identify the initial access path and persistence, validate clean recovery sources, rotate affected credentials and restore in stages with monitoring. Recovery completion requires business and security acceptance.

Escalate when

Encryption is active, several hosts or shares are affected, recovery systems are threatened or essential services are impaired. Invoke the major-incident process immediately where criteria apply.

Worked example

A workstation generates thousands of writes to a file share while a backup-admin account disables a job. Treat the endpoint and recovery-control activity as linked until investigated. Assign separate owners for containment, identity response and backup protection.

Reference: R02. Related cards: 43, 46, 54 and 58.

48 File identification hashing and metadata

Check this first

Use a dedicated analysis VM, preserve the original and work on a copy. Record collection time, source, original filename, size and SHA-256. Disable automatic previews and keep the environment patched; static parsers can also contain vulnerabilities.

Use these logs

Keep acquisition notes and tool output alongside endpoint delivery and execution evidence. A file copied from another system may have changed filesystem timestamps while its bytes remain identical.

Use these tools

Local inspection examples:

```
sha256sum evidence/sample.bin
file evidence/sample.bin
stat evidence/sample.bin
exiftool evidence/sample.bin
xxd -l 64 evidence/sample.bin
strings -a -n 6 evidence/sample.bin
```

Use strings -el for little-endian 16-bit text where supported. Run commands on the analysis copy, not the original forensic medium. Keep output in the case folder under restricted access.

Hash before and after authorised transfer. A matching hash supports byte-level integrity but does not prove the source was trustworthy or the file harmless.

48 Decisions and response

What the result means

Magic bytes can expose a misleading extension. Metadata may identify a creator or tool, but attackers can alter it. Embedded paths, URLs and names may be decoys or inactive strings. Do not treat them as confirmed execution artefacts.

Take this action

Record each finding with the command and version. Preserve exact bytes and a separate human-readable report. For an archive, list contents before extraction and apply file-count, size and nesting limits in an isolated environment to reduce archive-bomb risk.

Use local transformations for sensitive material. If decoding Base64 or decompression produces another file, hash that derived file and record the transformation. Do not overwrite the original. Protect outputs because strings or metadata can reveal credentials and personal data.

Escalate when

The file needs dynamic analysis, the parser fails unexpectedly, content is heavily protected, or sensitive data prevents use of available analysis services. Ask for specialist support rather than disabling safeguards.

Worked example

file identifies an attachment as a Windows shortcut despite its displayed PDF name. ExifTool exposes target information and EDR confirms a script child process. Preserve both static output and runtime evidence; the combination is stronger than either alone.

References: R15, R16 and R24. Related cards: 16, 17 and 53.

49 IP domain and DNS investigation commands

Check this first

Choose between existing records and a live query. Searching a downloaded log is local. Querying passive DNS sends the indicator to the provider. Running dig contacts a resolver, which may contact authoritative infrastructure. None of these actions is invisible by default.

Use these logs

Use original client DNS and event-time answers for historical attribution. Save resolver, query time, response code, TTL and answer. A current answer may differ from the incident's answer.

Use these tools

Examples for approved research:

```
dig example.com A +noall +answer
dig example.com AAAA +noall +answer
dig example.com NS +noall +answer
dig example.com TXT +noall +answer
dig -x 198.51.100.24 +noall +answer
whois 198.51.100.24
```

Use registry RDAP for current registration data where available.

Traditional WHOIS coverage varies. Reverse DNS is a label set within the relevant reverse zone, not proof of organisational ownership.

Avoid zone transfers, brute-force enumeration and active scans during routine triage unless explicitly authorised.

49 Decisions and response

What the result means

NXDOMAIN is a resolver response about the queried name at that time; caching, split DNS and policy filtering can affect what you see. A short TTL or unusual nameserver is not intrinsically malicious. TXT records serve many legitimate functions.

Take this action

Compare internal and approved external perspectives when relevant. Preserve evidence of split-horizon DNS instead of assuming one answer is wrong. Use passive historical data to investigate previous hosting and certificates without directly contacting the suspicious server.

Search exact indicators in logs before broad pattern matching. For example, use `rg -F` for a literal string; regex metacharacters can otherwise change the search. Separate a full hostname from its parent domain and include both only when the scope justifies it.

Escalate when

Queries correlate with suspicious processes, credentials were submitted to an imitation domain, or many endpoints share a new unexpected destination. Ask the DNS owner to validate suspected policy or resolver tampering.

Worked example

An external resolver returns NXDOMAIN while the endpoint used an internal DNS answer during the incident. Retain the internal record, its time and resolver. The external result does not invalidate the earlier observation.

Reference: R23. Related cards: 13, 14 and 44.

50 HTTP redirects and TLS investigation

Check this first

Live HTTP and TLS requests contact the server and can reveal your egress address or trigger tracking. Use only approved targets and an isolated analysis network. Inspect existing scan or proxy evidence first. Do not send corporate cookies, credentials or token-bearing URLs.

Use these logs

Proxy requests, browser telemetry, TLS metadata and previously captured redirects. Preserve the original URL and certificate evidence before creating redacted working copies.

Use these tools

Approved request to an example host, with no automatic redirects:

```
curl --head --max-time 15 --proto 'https' \  
https://example.com/
```

TLS inspection with hostname verification:

```
openssl s_client -connect example.com:443 \  
-servername example.com -showcerts \  
-verify_hostname example.com \  
-verify_return_error </dev/null
```

Review verification output; do not suppress errors with insecure options to make a result appear successful. Each redirect must be reviewed before following it.

50 Decisions and response

What the result means

HEAD responses can differ from GET responses, so a header check may miss malicious content. A valid certificate does not establish the site's business legitimacy. Certificate trust, hostname match and observed page behaviour are separate questions.

Take this action

Record status, Location, server headers, certificate subject/alternative names, issuer, dates and fingerprint as relevant. Treat headers as attacker-controlled claims. Preserve the request time and analysis vantage point because geofencing or content changes can affect results.

For an approved redirect investigation, capture each hop and assess its destination without blindly following a chain. Never replay password-reset or signed download links unless the owner authorises the consequence. Parsing stored responses locally is preferable when sufficient evidence already exists.

Escalate when

The chain leads to credential collection, payload delivery or unauthorised data transfer; a trusted application redirects unexpectedly; or certificate changes coincide with suspicious access.

Worked example

A header response shows a redirect from a compromised business page to an unrelated sign-in site. Existing proxy logs confirm the user followed it. Investigate credential submission and identity activity rather than assuming the original business domain was safe.

References: R21 and R22. Related cards: 14, 15 and 38.

51 PCAP analysis with TShark Wireshark and Zeek

Check this first

Work on a copy of the capture and record hash, capture point, time zone, snap length, packet loss and filtering. A PCAP is evidence from one vantage point, not a complete network history.

Use these logs

Compare packet times with flow, firewall, proxy and endpoint records. Note encrypted payloads, asymmetric routing and missing handshakes. These limit conclusions about content and session success.

Use these tools

Read a saved capture with name resolution disabled:

```
tshark -n -r evidence/traffic.pcap -q -z conv,tcp
tshark -n -r evidence/traffic.pcap -Y dns \
-T fields -e frame.time_epoch \
-e ip.src -e dns.qry.name
tshark -n -r evidence/traffic.pcap \
-Y 'http.request' -T fields \
-e http.host -e http.request.uri
```

For Zeek, run from a clean output directory because it writes logs to the working directory:

```
zeek -r ../evidence/traffic.pcap
```

Use -C only when checksum-offload artefacts justify ignoring checksums, and record that choice.

51 Decisions and response

What the result means

TShark -Y is a display filter applied while reading; capture filters use different syntax. No HTTP records may simply mean HTTPS encryption. Zeek connection logs summarise observed activity and do not prove every byte in a session was captured.

Take this action

Start with conversations, top talkers and relevant timestamps. Follow the suspicious stream in Wireshark and pivot to DNS, TLS or HTTP metadata. Use EDR to connect the network observation to a process. Preserve exported objects as potentially malicious evidence and never open them on production.

For Zeek, inspect conn.log and the protocol logs actually generated. Empty or missing logs may reflect traffic type, parser limits or capture quality. Retain tool version and command line so another analyst can reproduce the output.

Escalate when

You observe credential material, command traffic, sensitive data or exploitation requiring specialist interpretation. Restrict access to captures because they may contain personal data or secrets.

Worked example

A regular connection pattern appears in a PCAP, but TLS hides the payload. EDR identifies the process as an unapproved script interpreter. The combined evidence justifies escalation without claiming the encrypted commands were read.

References: R14 and R14B. Related cards: 31 and 44.

52 Windows event hunting with Chainsaw and Sigma

Check this first

Use exported EVTX files from authorised collection and work on copies. Record hashes, host, channels, time span and any export errors. Keep Chainsaw, mapping and rule versions together for reproducibility.

Use these logs

Security, Sysmon, PowerShell, System and other relevant operational channels. A collection containing only Security.evtx cannot satisfy rules that depend on Sysmon or PowerShell records.

Use these tools

Local search example:

```
chainsaw search powershell -i evidence/evtx/
```

Hunt example with separately obtained rule and mapping directories:

```
chainsaw hunt evidence/evtx/ \  
-s rules/sigma/ \  
--mapping mappings/sigma-event-logs-all.yml \  
--json --output output/chainsaw.json
```

Confirm flags with the installed version's help. The paths are workspace examples; create an approved output folder and use the actual mapping shipped with your Chainsaw release. Kali package availability does not mean every dependency or rule set is preinstalled.

52 Decisions and response

What the result means

A Sigma match is a lead based on rule logic and field mapping. It is not an incident verdict. Rules may be experimental, noisy or unsupported by a particular backend. No matches can reflect missing logs, incompatible fields or rules that never loaded.

Take this action

Review load errors and the number of rules successfully processed. Inspect each candidate in native event context. Correlate host, user, time and process across channels. Keep false-positive explanations specific to the observed activity.

For a new hunt, state the behaviour hypothesis, required telemetry and expected evidence before choosing rules. Save both findings and limitations. Feed validated coverage gaps into the detection backlog rather than claiming broad ATT&CK coverage from a rule count.

Escalate when

Several related behaviours form an execution chain, privileged access is implicated or a critical source cannot be parsed. Ask the detection owner to resolve mapping or rule-conversion failures.

Worked example

A task-creation rule matches an inventory job. Another record shows the same task action changed to a user-writable script just before suspicious network activity. Investigate the update sequence rather than dismissing the task because its original purpose was legitimate.

References: R26 and R27. Related cards: 25, 40 and 42.

53 Static malware Office and PDF analysis

Check this first

Use a patched isolated VM and a copy of the file. Disable automatic previews and unnecessary networking. Static analysis does not intentionally execute the sample, but parsers still process untrusted input and must be treated cautiously.

Use these logs

Correlate static findings with delivery, execution and endpoint behaviour. Preserve original and derived artefacts separately, including extracted scripts, attachments and decoded content.

Use these tools

Examples, subject to installed tool versions:

```
yara rules/triage.yar evidence/sample.bin  
capa evidence/sample.bin  
oleid evidence/document.docm  
olevba evidence/document.docm  
pdfid.py evidence/document.pdf
```

Use trusted, reviewed rules and record their revision. Tools such as pdf-parser may support deeper object inspection in an approved lab. REMnux or FLARE-VM may be a better fit for specialised analysis than a general Kali installation.

Never enable macros or execute embedded JavaScript merely to complete triage. Do not download malware samples from public repositories as part of an ordinary alert check.

53 Decisions and response

What the result means

YARA reports matching patterns. capa infers code capabilities and may be limited by packing or unsupported content. Macro presence is not proof of maliciousness, and macro absence does not clear all document threats. PDF structural flags identify features needing review, not a final verdict.

Take this action

Answer a narrow question: what can this file do, what content does it reference, and does endpoint evidence show that action? Inspect suspicious paths, commands, URLs and embedded objects without activating them. Preserve exact transformations and hashes.

If packing, encryption or runtime behaviour prevents a safe conclusion, refer the sample to the malware-analysis team. Use approved private sandboxes only after confidentiality review. A sandbox observation is behaviour in that environment, not proof that the same action occurred on the user's device.

Escalate when

The file targets credentials, establishes persistence, evades analysis beyond your remit or contains sensitive organisational data. Escalate evidence of trusted-package tampering to software and incident owners.

Worked example

olevba identifies a macro that builds a command from several strings. The decoded command references an external host, but no endpoint execution is yet known. Report suspicious capability and continue runtime scoping; do not report confirmed execution solely from the macro.

References: R15, R16 and R28. Related cards: 16, 17, 34 and 48.

54 Containment decision matrix

Check this first

Choose the action that reduces the observed risk while preserving recovery options. Confirm your authority, the business owner, likely service impact and how success will be verified. Do not assume a technically available button is an authorised action.

Use these logs

Use current activity, asset criticality, identity dependencies, response history and evidence needs. Identify whether harm is occurring on a host, through an identity, through a cloud application or across several paths.

Use these tools

Threat path	Candidate action	Important limit
Endpoint execution	Isolate host	Does not revoke cloud sessions
Stolen identity	Restrict account and revoke sessions	App sessions may persist
Malicious message	Preserve then purge or block	Does not undo user actions
Specific destination	Precise network or URL block	Shared service collateral
Malicious app grant	Remove grant or credential	Other persistence may remain

Use emergency procedures for immediate harm when pre-authorised. Log the action and decision even if approval is retrospective under that procedure.

54 Decisions and response

What the result means

Containment limits ongoing access; eradication removes the cause and persistence; recovery restores trusted operation. These are separate outcomes. One containment action can succeed while another attack path remains open.

Take this action

Record the target, reason, approver, expected effect, rollback plan, request time and completion evidence. Verify the action in the relevant system and monitor for continued activity. Use an out-of-band communication route if the collaboration environment may be compromised.

Preserve volatile or short-retention evidence where feasible without prolonging active destruction. Coordinate critical servers, medical/industrial systems and essential business services with appropriate owners. Do not apply workstation procedures blindly to specialised systems.

Escalate when

The action affects a critical service, requires authority you lack, risks safety, has no reliable rollback or fails to stop activity. Escalate disagreement over business impact to the incident commander.

Worked example

A compromised user's laptop is isolated, but a cloud application grant continues reading mail. Add the appropriate identity/application containment task and verify it separately. Reporting "contained" after only host isolation would be misleading.

Use Appendix I for the sample escalation matrix. References: R01 and R05. Related cards: 55 through 59.

55 Identity compromise response

Check this first

Identify the affected principal, active sessions, privileges and applications. Distinguish password compromise, token theft, malicious consent, added credentials and federation or directory compromise. Each leaves different access paths.

- Verify the person through a trusted channel.
- Preserve sign-in, audit and resource-access evidence.
- Check added MFA methods, recovery options, roles and grants.
- Identify devices where secrets or sessions may have been stolen.
- Assess service dependencies before disabling workload identities.

Use these logs

Identity provider, AD, VPN, endpoint, mailbox, application and cloud audit. Review non-interactive and service-principal access as appropriate. Search before the first alert to identify the earliest supported compromise.

Use these tools

Use approved identity administration. A response may include restricting access, resetting credentials, revoking sessions, re-registering MFA and removing unauthorised grants or secrets. Apply only actions justified by the access path and local authority.

Coordinate hybrid accounts across relevant systems; a single-console action may not cover every identity store.

55 Decisions and response

What the result means

Password change does not necessarily invalidate every application session or remove an OAuth grant. Session revocation behaviour varies by provider and application. A clean endpoint scan does not clear cloud persistence.

Take this action

Verify each response action and continue reviewing target-application activity. Remove unauthorised mailbox rules, delegates, roles and credentials after preserving evidence. Rotate dependent secrets in an approved order with application owners.

Scope data access and actions performed during the compromised period. Restore the user's access only after identity ownership is verified, affected devices are trusted and required security methods are re-established. Define a monitoring window based on the incident and available retention.

Escalate when

Privileged or emergency accounts, workload identities, federation trust, multiple users or sensitive data are involved. Escalate any activity continuing after expected revocation.

Worked example

The team restricts a compromised user, revokes sessions and resets the password. A separate review removes a malicious mail app grant and an added recovery method. Monitoring then checks both user and application access. Each action has its own completion record.

Reference: R05. Closure requires the access paths addressed, downstream scope documented, recovery approved and monitoring assigned. Related cards: 19, 38, 39 and 60.

56 Endpoint compromise response

Check this first

Confirm device identity, role, active harm and sensor reachability. Capture process, user, network and persistence context. Determine whether the device is a workstation or a critical server with service dependencies.

- Preserve raw alert and relevant telemetry.
- Identify active remote sessions and exposed identities.
- Confirm containment authority and business impact.
- Request volatile or forensic collection where justified.
- Identify other devices with the same behaviour.

Use these logs

EDR, native host events, network, identity, software deployment and file evidence. Record collection limitations and whether the device was offline during the suspected activity.

Use these tools

Use approved isolation and collection capabilities. Do not install unreviewed tools, run the malware again or disable protective controls for convenience. Preserve evidence before wiping where feasible.

Verify isolation completion and understand any management-channel exceptions. Identity containment is a separate task if credentials or tokens were exposed.

56 Decisions and response

What the result means

Deleting a detected file may leave persistence or stolen access.

Reimaging can remove host artefacts but does not automatically revoke cloud sessions or rotate secrets. A successful antivirus scan is one control result, not a complete recovery test.

Take this action

Determine the initial access path and scope. Remove persistence or rebuild from a trusted source according to incident policy. Patch the entry point, restore only validated data and rotate affected credentials with owners. Validate application function and security telemetry before reconnection.

Search peers for the same delivery, process chain, persistence and destinations. Maintain evidence integrity and track who collected or transformed artefacts. Choose a risk-based enhanced-monitoring period and assign its owner and closure trigger.

Escalate when

Credential theft, kernel-level compromise, trusted-software tampering, lateral movement, critical services or repeated reinfection is involved. Use specialists for full forensic conclusions.

Worked example

A laptop is rebuilt after malicious script execution. Before normal access is restored, the team revokes stolen sessions, removes an app grant, patches the delivery weakness and verifies new sensor telemetry. Rebuild alone would have left the cloud access path unresolved.

Closure requires trusted host state, access-path remediation, relevant identity actions, peer scope and business acceptance. Related cards: 21, 43, 54 and 60.

57 Phishing and BEC response

Check this first

Assign an incident owner and classify the interaction. Delivery, click, credential entry, execution, payment and data disclosure require different follow-up. Preserve the original message before approved removal.

- Identify all recipients and human interactions.
- Confirm any payment or sensitive-data request independently.
- Check identity and endpoint consequences.
- Review internal sending or compromised vendor accounts.
- Notify finance/fraud promptly when funds are at risk.

Use these logs

Message trace, gateway actions, click telemetry, identity, mailbox audit, EDR and relevant business records. Use message IDs and artefact hashes rather than subject alone when scoping.

Use these tools

Use approved purge, block and account-response workflows. Preserve evidence and verify action success for each mailbox or policy target. A command submitted to the mail platform may still have failures or incomplete scope.

Do not interact with suspected attackers, make payments or send external notifications without designated authority.

57 Decisions and response

What the result means

Purge removes accessible messages where the platform supports it; it cannot undo a user's prior action or remove every downloaded copy. Blocking a sender does not stop an attacker using another account or a stolen session.

Take this action

Apply identity response for credential or session exposure and endpoint response for execution. For BEC, coordinate transaction hold/recall through authorised finance procedures. Review forwarding, delegates, consent and sent messages where account misuse is suspected.

Communicate specific instructions to affected users: do not interact, report what occurred and use the approved support contact. Avoid distributing live malicious links in broad awareness messages. Record removal failures, remaining offline copies and monitoring tasks.

Escalate when

Money moved, sensitive data was shared, several users are affected, an internal account sent the campaign or the attacker remains active. Involve privacy/legal and business owners through the response process.

Worked example

Twenty users received the email; two clicked, one entered credentials and none executed an attachment. The email team verifies purge, the identity team contains one account and the SOC reviews both clicked sessions. The report distinguishes exposure from confirmed compromise.

Closure requires recipient scope, verified actions, downstream investigations and business impact documented. Related cards: 33, 34, 35 and 60.

58 Ransomware response

Check this first

Invoke the major-incident process when local criteria are met. Prioritise stopping active destruction and protecting recovery capability. Identify affected systems, remote-write sources, privileged accounts and backup or virtualisation controls.

- Verify which systems are encrypting now.
- Coordinate network and host isolation through emergency authority.
- Protect backup access and immutable/offline copies.
- Preserve key evidence where feasible without delaying harm reduction.
- Establish a trusted communication channel and action log.

Use these logs

Endpoint, identity, storage, file-server, virtualisation, backup and network audit. Review earlier credential access and data movement because encryption may follow a longer intrusion.

Use these tools

Use approved containment and forensic workflows. Avoid unverified decryptors, indiscriminate rebooting and restoration into an environment where the access path remains open. Any negotiation, payment or external coordination belongs to designated organisational leadership.

Document the reason when an emergency power action is necessary; it may destroy volatile evidence and affect recovery.

58 Decisions and response

What the result means

Stopping encryption is not the same as removing the attacker. Restoring files does not resolve stolen credentials or data exposure. Backups can be intact but unsafe to restore if they contain persistence or were created after compromise.

Take this action

Run parallel workstreams under incident command: containment, identity, evidence, data exposure, recovery and communications. Give each a named owner. Reconstruct initial access and lateral movement, validate trusted restore points and remediate the entry path.

Restore in controlled stages. Verify integrity, business function, security agents, logging and access controls. Watch for reappearance of indicators and behaviour. Record recovery acceptance and residual risk; do not close the incident solely because services are available again.

Escalate when

Essential services, multiple business units, recovery infrastructure, sensitive data or third parties are affected. Use current organisational and legal notification procedures rather than assuming a universal reporting deadline.

Worked example

The team isolates affected workstations and blocks compromised administration. Backup owners validate a pre-incident restore point in a separated environment. Identity owners rotate exposed secrets, and the SOC checks restored systems before staged release. Each workstream reports its evidence and remaining risk.

Reference: R02. Related cards: 43, 46, 47 and 54.

59 L1 to L2 to incident response escalation

Check this first

Escalate when the risk, complexity or required authority exceeds your role. L1 typically validates and gathers core evidence; L2 scopes and correlates; incident response leads containment and recovery where declared. Local role definitions take precedence.

- State the decision or expertise required.
- Identify active harm, critical assets and current confidence.
- Include the best evidence and important contradictions.
- Explain completed actions and unverified requests.
- Name the current owner and next update time.

Use these logs

Attach the trigger, minimal timeline, affected entities, query details and response results. Keep the full evidence package in a protected location and include a usable link.

Use these tools

Use the approved urgent channel plus the case system. Phone or page the on-call responder when active harm requires immediate attention. Do not assume email delivery or a chat reaction is ownership acceptance.

If the primary responder is unavailable, follow the documented backup path. Record the attempt and escalation time.

59 Decisions and response

What the result means

Escalation transfers a defined responsibility when accepted; it does not erase the originating analyst's evidence obligations. A case can need specialist help while L1 continues recipient scope or telemetry collection.

Take this action

Use a concise escalation packet: case ID; why now; what happened; known scope; evidence; actions; gaps; requested decision. Keep technical depth in linked evidence. Acknowledge receipt and confirm who owns the next action.

For critical systems, identify the service owner and expected containment impact. If there is disagreement, record options and risk for the incident commander. Continue safe evidence collection within your authority while awaiting the decision.

Escalate when

There is active encryption, suspected data theft, privileged compromise, lateral movement, control tampering, major business impact or inability to contain. Do not wait for a complete report before raising an urgent incident.

Worked example

"SOC-041: request IR lead and server-isolation decision. A web service launched a shell and created an unknown task. EDR evidence E03 and E04 support execution. One production host confirmed; two peers pending review. No containment yet because isolation interrupts the service. App owner contacted; next update 15:20 UTC."

Use Appendix J for the reusable template. Related cards: 04, 08, 12 and 54.

60 Incident summary closure and handover

Check this first

Check whether the evidence supports closure. Confirm containment, eradication or approved risk treatment, recovery, scope, impact and required follow-up. If an essential question remains unanswered, record it and obtain the appropriate decision rather than hiding it in the summary.

- State what happened and how it was detected.
- Identify confirmed affected assets, identities and data.
- Separate observed impact from potential exposure.
- List completed actions with verification.
- Name residual-risk and improvement owners.
- Define monitoring and reopening conditions.

Use these logs

Use the final timeline, evidence register, action audit, business acceptance and monitoring results. Reconcile contradictory counts and timestamps before publishing.

Use these tools

Use the case system and approved report template. Keep sensitive indicators, tokens and personal data in restricted appendices where needed. Management summaries should explain consequences and decisions without overstating technical certainty.

60 Decisions and response

What the result means

"No further activity observed" is limited to the stated sources and period. "No data loss" needs stronger evidence than an absence of DLP alerts. MTTR is ambiguous unless the organisation defines whether it measures response, remediation or recovery.

Take this action

Write the summary in five elements: incident, scope, impact, verified response and remaining work. State the observation window and telemetry limits. Assign lessons learned to owners with due dates and a way to verify completion.

For metrics, preserve start and end definitions. Measure time from detection to acknowledgement separately from containment and recovery. Do not reset timestamps when ownership changes. Track repeated root causes and detection gaps, not just case volume.

Escalate when

Business acceptance is missing, containment is unverified, regulatory assessment is unresolved, sensitive data scope remains unknown or activity recurs. Reopen or link a new incident according to local policy.

Worked example

"One user account was used without authorisation. Mail rules and an app grant were removed; session restrictions were verified. No additional affected accounts were found in the reviewed identity logs from 24 to 25 September. Mail-access scope remains under privacy review. Identity engineering owns preventive changes; SOC owns enhanced monitoring."

The fictional example preserves uncertainty while giving a clear operational status. References: R01 and R05. Related cards: 11, 12 and Appendix J.

QUICK REFERENCE

Appendix A Any alert checklist

Triage in the order the evidence supports

1. Preserve the original alert, raw records and detection rule context.
2. Confirm UTC and local time, source coverage and ingestion delay.
3. Resolve accounts, devices, processes and network endpoints.
4. Determine attempted, successful, blocked and unknown actions.
5. Check business criticality, privilege, sensitive data and active harm.
6. Build a timeline and test at least one alternative explanation.
7. Scope related entities using time-aware pivots.
8. Request justified, authorised containment and verify completion.
9. Escalate with evidence, a decision request, owner and update time.
10. Close only with supported disposition and assigned residual work.

Before using an external resource

Check classification, approval, visibility, retention and use terms. Lookups share queries; unlisted scans are not private. Never submit customer data, internal documents, tokens or credentials to public analysis or AI services.

Before using a command

Confirm the target, read local help and protect originals. Distinguish local processing from network contact. Queries need local field mapping and a bounded interval. These examples do not authorise scanning, exploitation or system changes.

Record the limit of the conclusion

State the sources and interval searched, not "nothing happened". Worked examples are fictional, using reserved example names or documentation addresses. Local policy and authorised incident command take precedence.

QUICK REFERENCE

Appendix B Ports and protocols

Port	Typical service	Analyst question
22 TCP	SSH	Expected remote administration?
25 465 587 TCP	SMTP services	Server delivery or user submission?
53 TCP/UDP	DNS	Expected resolver and query pattern?
80 TCP	HTTP	Which host path and process?
88 TCP/UDP	Kerberos	Expected client and service?
123 UDP	NTP	Trusted time source?
135 TCP	RPC endpoint mapper	What later dynamic connection?
389 TCP/UDP	LDAP and CLDAP	Expected directory activity?
443 TCP/UDP	HTTPS and HTTP3	Expected app and destination?
445 TCP	SMB	Which share account and file?
636 TCP	LDAPS	Expected directory connection?
1433 3306 5432 TCP	Common databases	Approved client and query path?
3389 TCP/UDP	RDP	Expected source session and owner?
5985 5986 TCP	WinRM	Approved remote management?
8080 8443 TCP	Alternate web services	What actually listens here?

Ports do not prove protocol or intent. TLS, proxies, tunnels and NAT can obscure the application. Validate application evidence and configuration.

Private IPv4: 10.0.0.0/8, 172.16.0.0/12 and 192.168.0.0/16. Other special-purpose ranges are not automatically public. Documentation ranges: 192.0.2.0/24, 198.51.100.0/24 and 203.0.113.0/24.

QUICK REFERENCE

Appendix C Windows event quick table

Event	Meaning to verify
4624 4625	Successful or failed logon
4634 4647	Session end or user initiated logoff
4648 4672	Explicit credentials or special privileges
4688 4689	Process creation or termination
4697	Service installed in Security audit
7045	Service installed in System SCM provider
4698 4702	Scheduled task created or updated
4699 4700 4701	Task deleted enabled or disabled
4720 4722	User created or enabled
4723 4724	Password change or reset attempt
4725 4726 4738	User disabled deleted or changed
4728 4729	Global group member added or removed
4732 4733	Local group member added or removed
4756 4757	Universal group member added or removed
4768 4769 4771 4776	Kerberos and NTLM context
4719 1102	Audit policy change or Security log cleared

Always retain provider, channel, host, event version and record ID. Audit policy determines availability. Object access and directory changes may need additional configuration. Event IDs alone are not incident verdicts.

Logon type reminders: 2 interactive; 3 network; 4 batch; 5 service; 7 unlock; 9 new credentials; 10 remote interactive; 11 cached interactive. Correlate account, source, logon ID and subsequent actions. References: R04, R11 and R12.

QUICK REFERENCE

Appendix D Sysmon and PowerShell quick table

Source and event	Investigation use
Sysmon 1	Process creation and parent context
Sysmon 3	Process attributed network connection
Sysmon 6 7	Driver or image loaded
Sysmon 8 10	Remote thread or process access
Sysmon 11 15	File creation or named stream
Sysmon 12 13 14	Registry creation value or rename
Sysmon 16	Configuration changed
Sysmon 19 20 21	WMI subscription components
Sysmon 22	DNS query
Sysmon 23 26	File deletion with or without archive
Sysmon 25 255	Process tampering or sensor error
PowerShell 4103	Module logging when configured
PowerShell 4104	Script block logging when available

Use ProcessGuid, device and UTC time to connect Sysmon events. Network and image-load logging are configuration-dependent. Do not infer no activity when the event type was not collected.

PowerShell records can contain sensitive commands or secrets. Restrict access and consider protected logging under approved configuration. AMSI detections are product-dependent and do not replace script or process telemetry.

Investigate security-control tampering alongside the suspected intrusion. In ATT&CK v19, Stealth and Defense Impairment replace the previous combined Defense Evasion tactic. Use the current technique

entry and observed behaviour rather than mapping an entire alert solely from its title. References: R03, R13 and R29.

QUICK REFERENCE

Appendix E Process relationships worth reviewing

Parent or context	Child or action	First validation
Word processor	Shell or script	Document origin and deployment
Browser	Shell after user interaction	Pasted command or installer
Web server	Shell or system utility	App function or exploitation
Archive utility	Shortcut then interpreter	Extracted content and user action
Mail client	Script or unexpected executable	Attachment and preview behaviour
WMI provider	Unexpected process	Remote operator and approval
Service controller	New unsigned service binary	Service config and installer
Task engine	Script in writable directory	Task XML and creator
Remote support tool	Credential or data access	Operator identity and session
Unknown process	LSASS access or dump file	Access rights signer and purpose

These are leads, not universal rules. Relationships vary by OS and execution method. Validate path, signer, hash, user, process start and command.

Ask: Is the content source trusted? Is this action expected? Do independent logs show harm? Trusted binaries can run malicious arguments; unfamiliar binaries may belong to approved workflows.

Keep exceptions narrow and time-limited. Do not allowlist every administrator shell or a whole remote-support product. References: R07 and R25.

QUICK REFERENCE

Appendix F OSINT bookmarks for artefacts

Resource	Daily purpose	Guardrail
VirusTotal	Hash IP domain URL context	Search before upload
urlscan	Existing website scans and redirects	New scan visits target
GreyNoise	Observed internet scanning context	Coverage is not universal
AbuseIPDB	Community IP abuse history	Reports are not a verdict
Shodan	Indexed exposed services	Observation may be stale
Censys	Hosts services and certificates	Shared infrastructure
ICANN Lookup	Domain registration via RDAP	Redaction limits ownership
crt.sh	Certificate transparency	Certificate is not endorsement
SecurityTrails	DNS history and relationships	Access depends on plan

Start with internal telemetry. Public enrichment adds context but cannot establish what happened inside your environment. Preserve the source URL, lookup time, relevant observation time and confidence.

Existing-record search is different from a scan request. Both share information with a service; a scan can also contact the target. Account requirements, quotas, API keys, historical depth and permitted commercial use change. Check the current terms before operational integration.

QUICK REFERENCE

OSINT bookmarks for behaviour and exposure

Resource	Daily purpose	Guardrail
URLhaus	Malware distribution URLs	Not all phishing coverage
ThreatFox	Malware associated indicators	Check age and context
MalwareBazaar	Malware hash and sample context	Do not casually download samples
CISA KEY	Known exploitation context	Not your asset inventory
FIRST EPSS	CVE exploitation probability	Not local compromise probability
MITRE ATTACK	Behaviour and technique mapping	Map evidence not titles
LOLBAS and GTFOBins	Legitimate utility abuse	Context determines intent
CyberChef	Decode and transform data	Prefer approved local copy
MXToolbox	Public mail and DNS checks	Do not expose internal headers

For dynamic file analysis, use an organisation-approved private sandbox. [ANY.RUN](#) and [Hybrid Analysis](#) are examples to assess, not blanket approval to upload. Confirm visibility, sharing, retention and contractual controls for the specific service and plan.

Daily briefing: review vendor advisories for deployed products, CISA KEY and relevant [MyCERT advisories](#). Record applicability and an action owner; a news item alone is not an incident. Do not enter credentials or tokens into public decoding services.

QUICK REFERENCE

Appendix G Local defensive command sheet

Work on authorised copies in an analysis VM

```
# Exact indicator in a local text export
rg -n -F '198.51.100.24' evidence/firewall.log
# File identity and integrity
file evidence/sample.bin
sha256sum evidence/sample.bin
# Metadata and readable strings
exiftool evidence/sample.bin
strings -a -n 6 evidence/sample.bin
# First bytes
xxd -l 64 evidence/sample.bin
# JSON Lines into selected columns
jq -r '[".time,.user,.src"] | @tsv' \
  evidence/events.jsonl
# Unique lines sorted by frequency
sort evidence/domains.txt | uniq -c | sort -nr
# Local Windows event search
chainsaw search powershell -i evidence/evt/
# Offline packet conversations
tshark -n -r evidence/traffic.pcap -q -z conv,tcp
```

The jq example requires records with time, user and src keys; map real fields first. Preserve the raw export and treat derived lists as analysis, not replacement evidence. Search syntax, encoding and line endings affect results.

Before connecting to anything

dig contacts DNS; whois or RDAP contacts a registration service; curl and openssl s_client contact the destination. Use approved egress and scope. Do not run these against token-bearing links or suspicious infrastructure from a corporate workstation without the approved investigation workflow.

The command examples require installed tools and version checks. They have not been executed against the reader's systems. Keep API

secrets out of commands, shell history and case screenshots. Related cards: 48 through 53.

QUICK REFERENCE

Appendix H QRadar AQL query patterns

Bound the search before broadening it

These are read-only patterns. Validate normalised fields, log-source parsing and time zone in your deployment. Query limits cap returned records; they do not guarantee all relevant evidence was returned.

Events involving an example address:

```
SELECT starttime, sourceip, destinationip,
  username, QIDNAME(qid) AS event_name
FROM events
WHERE sourceip = '198.51.100.24'
  OR destinationip = '198.51.100.24'
ORDER BY starttime DESC
LIMIT 200
LAST 24 HOURS
```

Review direction and raw payload. QID is a QRadar classification identifier, not the original Windows event ID.

Counts by log source:

```
SELECT LOGSOURCENAME(logsourceid) AS log_source,
  COUNT(*) AS records,
  SUM(eventcount) AS represented_events
FROM events
GROUP BY logsourceid
ORDER BY represented_events DESC
LAST 1 HOURS
```

Coalescing can make represented events differ from stored record count. Low volume is meaningful only against the source's normal schedule and expected ingestion.

For Windows Event ID, command line and hashes, confirm the actual parsed or custom property names before querying. Do not assume a universal property called EventID or SHA256. Save the query, console time zone and exact execution time. Reference: R30.

QUICK REFERENCE

Microsoft KQL query patterns

Identity example for a connected Log Analytics SigninLogs table:

```

SigninLogs
| where TimeGenerated > ago(24h)
| where ResultType == "50126"
| summarize Failures=count(),
  Users=dcount(UserPrincipalName)
  by IPAddress, bin(TimeGenerated, 15m)
| where Users >= 10
| order by Failures desc

```

This is a candidate-generation threshold, not a production rule. Code 50126 concerns credential validation; verify the current provider description. Review successful sessions and raw records afterward. Other failures or interrupted sign-ins require different interpretation.

Process example for Defender advanced hunting:

```

DeviceProcessEvents
| where Timestamp > ago(24h)
| where FileName in~ ("powershell.exe", "pwsh.exe")
| project Timestamp, DeviceName, AccountName,
  FileName, ProcessCommandLine,
  InitiatingProcessFileName
| order by Timestamp desc
| take 200

```

This lists interpreters; it does not label them malicious. Add the observed device, account, command or time interval. These two examples use different schemas and time fields. They are not interchangeable merely because both use KQL.

Record ingestion coverage, retention, licensing and any omitted non-interactive or service-principal tables. References: R06 and R07.

QUICK REFERENCE

Splunk SPL query patterns

Assumptions: index=wineventlog, sourcetype=WinEventLog:Security, and extracted fields EventCode, IpAddress and TargetUserName.

Replace these with your actual index, sourcetype and field mapping; XML ingestion can differ.

Failed-logon candidates:

```
index=wineventlog sourcetype=WinEventLog:Security
earliest=-24h latest=now EventCode=4625
| bin _time span=15m
| stats count AS failures
  dc(TargetUserName) AS users
  by _time IpAddress
| where users >= 10
| sort - failures
```

Review failure reasons and search related successes; the example threshold is illustrative. Missing extracted fields can silently change groupings.

Account timeline:

```
index=wineventlog sourcetype=WinEventLog:Security
earliest=-24h latest=now
TargetUserName="maya"
| table _time host EventCode TargetUserName
  IpAddress LogonType
| sort 0 _time
```

Normalise account domain and SID to avoid merging unrelated users. The result is limited by source ingestion and retention. Save the raw events needed to support your conclusions.

For every platform, test syntax and field coverage on known benign records before adapting a pattern into a scheduled detection. No query in this appendix is a universal drop-in detection. Reference: R31.

QUICK REFERENCE

Appendix I Severity and escalation matrix

Example level	Evidence and impact	Response owner
Critical	Active widespread destruction or major service impact	Incident commander and IR immediately
High	Unauthorised access, privilege misuse or likely sensitive-data exposure	L2 or IR with service owner
Medium	Credible suspicion; bounded scope; no established major impact	Analyst with L2 support
Low	Limited suspicious or blocked activity needing validation	Queue owner under local targets

Sample matrix only: local definitions, response targets, authority and contracts take precedence. Record severity, priority and confidence separately.

Immediate escalation triggers

- Active destruction or attacks on recovery systems.
- Privileged or emergency account compromise.
- Suspected sensitive-data transfer or financial fraud.
- Lateral movement or multiple affected hosts.
- Control tampering, failed containment or critical telemetry loss.
- Containment that threatens critical services or safety.

Minimum handoff

Include case ID, service, evidence, priority, confidence, actions, unknowns, decision requested, owners and next update. Verify acceptance or formal assignment before transferring ownership.

Keep contact details in a controlled directory, not this distributed book. Related cards: 08, 54 and 59.

QUICK REFERENCE

Appendix J Case and evidence templates

Triage record

Case ID and owner: _____

Alert time UTC and local zone: _____

Rule name version and raw record ID: _____

Asset account process and criticality: _____

Confirmed behaviour and outcome: _____

Query platform time range and result: _____

Alternative explanation and verification: _____

Priority confidence and rationale: _____

Next action owner and update time: _____

Evidence register fields

Evidence ID; description; source system; collector; collection time and zone; method/tool version; original location; SHA-256 where applicable; protected storage path; transformations; access/transfer history; retention owner.

Keep originals and derived files separate. A screenshot is useful context but may omit raw fields and source identifiers. Record failed collection and missing evidence as well as successful exports.

Timeline record fields

Original timestamp; source zone; normalised UTC; host or identity; action; result; evidence ID; observed or inferred; confidence; analyst note. Preserve clock corrections and ingestion delay separately.

QUICK REFERENCE**Escalation message template**

Case [ID] requires [decision or specialist help]. We observed [specific behaviour] on [asset/account] at [UTC time]. Evidence [IDs] supports [finding]. Known scope is [entities]; [scope limit] remains unknown. Completed actions are [verified results]. Please [requested decision]. Current owner is [name/role]; next update is [time].

Shift handover template

Current status and priority: _____

Last confirmed activity and containment: _____

Pending action owner and due time: _____

Evidence location and query links: _____

Reopening or escalation trigger: _____

Receiving analyst and acknowledgement: _____

Incident summary template

What happened: [plain-language finding]. Scope: [confirmed entities and reviewed period]. Impact: [observed effect and potential exposure separately]. Response: [verified actions]. Remaining work: [owner, due time, risk]. Monitoring: [sources, period, trigger and closure authority].

Closure checklist

- Disposition is supported by evidence and coverage limits.
- Required containment and recovery are verified.
- Business and incident owners accept the outcome where required.
- Residual risk and legal/privacy review have named owners.
- Improvements have due dates and verification criteria.
- Metrics use defined start and end points, not an ambiguous MTTR label.

PRIMARY SOURCES

Technical references

Operational guidance and telemetry

Reference links were checked for this edition on 25 September 2026. Product schemas, access terms and command options can change. Recheck the linked primary documentation when implementing or updating a procedure.

R01 NIST SP 800 61 Revision 3 - Incident response within CSF 2.0.

R02 CISA StopRansomware Guide - Ransomware prevention and response considerations.

R03 Microsoft Sysmon - Event definitions and collection configuration.

R04 Microsoft Event 4688 - Process creation and command-line fields.

R05 Microsoft Entra emergency access revocation - Identity and application session limitations.

R06 Microsoft SigninLogs schema - Cloud sign-in fields and result interpretation.

R07 Microsoft DeviceProcessEvents schema - Defender process-hunting fields.

R08 VirusTotal API overview and private scanning - Lookup and submission distinctions.

R09 urlscan visibility - Public unlisted and private scan handling.

R10 Microsoft audit activities - Microsoft 365 operation meanings.

R11 Microsoft advanced audit policy - Security event categories.

R12 Microsoft events to monitor - Event reference and prerequisites.

R13 Microsoft PowerShell logging - Script logging and sensitive-data considerations.

PRIMARY SOURCES

Tools queries and threat mapping

[R14 TShark manual](#) and [R14B Zeek quick start](#) - Offline packet analysis.

[R15 Mandiant capa](#) and [R16 oletools](#) - Static capability and document inspection.

[R17 CISA KEV](#) and [R18 FIRST EPSS](#) - Exploitation context and probability.

[R19 AWS CloudTrail management events](#) and [R20 Google Cloud audit logs](#) - Cloud visibility boundaries.

[R21 curl manual](#) and [R22 OpenSSL s_client](#) - HTTP and TLS command options.

[R23 Kali BIND tools](#) and [R24 ExifTool](#) - DNS and metadata inspection.

[R25 LOLBAS](#) and [GTFBins](#) - Legitimate utilities and abuse behaviours.

[R26 Chainsaw](#) and [Kali package](#) - Event search hunt and mappings.

[R27 Sigma rule documentation](#) and [R28 YARA command line](#) - Rule structure and execution.

[R29 MITRE ATTACK updates](#) - Version 19.2 current at the edition date; map observed behaviour to current entries.

[R30 IBM AQL examples](#) - QRadar event queries and syntax.

[R31 Splunk search reference](#) - Aggregation and field-dependent SPL patterns.

Resource bookmarks in Appendix F link to the respective operators. No service is endorsed as automatically approved for confidential organisational data. The book's checklists, examples and suggested decisions require adaptation to local authority, telemetry and business context.